

QUESTION 1 [65 Marks]

You have been engaged as a Security Analyst for QuickDeliver Sdn. Bhd., a Malaysian food delivery platform based in Johor Bahru. The development team has submitted the PHP application source code (**Appendix A**) and the project dependency manifest (**Appendix B**) for a security assessment before the platform's public launch. Your assessment must cover both source code vulnerabilities and third-party library vulnerabilities identified from the National Vulnerability Database (NVD).

- a) Review Appendix A (source code) and Appendix B (*composer.json*) to answer the following.
- i. From Appendix A, identify and list the potential security vulnerabilities found in the QuickDeliver source code. For each vulnerability, state the affected function name, a brief description of the flaw, and the corresponding OWASP Top 10 (2025) category.

No	Affected function	Vulnerability Description	OWASP Top 10 2025 Category
1	Global Scope (\$db, \$PAYMENT_API_KEY) & sendConfirmationEmail()	Exposure of sensitive credentials (Hardcoded Secrets) – Sensitive credentials, including the database password (QkDel!v3r2025), payment API identification (pgw_live_sk_...) and SMTP password (SMTPp@ssQD2025!), are explicitly placed in the source code and if the source code is compromised, then a hacker can get unauthorized access to the database, payment gateway and email services.	A02:2025 - Security Misconfiguration
2	searchRestaurants()	SQL Injection (SQLi). The keyword parameter (\$_GET['keyword']) has been directly concatenated to the SQL statement, without the use of any sort of sanitization or parameterization. The attacker	A05:2025: - Injection

		may inject malicious SQL content to read, modify, or delete database records.	
3	<code>searchRestaurants()</code>	Reflected Cross-Site Scripting (XSS). The <code>\$_GET['keyword']</code> variable is outputted directly into the HTML output without encoding using HTML entities. The attacker can insert harmful JavaScript code that will execute in the browser of the victim.	A05:2025- Injection
4	<code>placeOrder()</code>	Missing CSRF (Cross-Site Request Forgery) Token – The system either does not generate or check for the presence of an anti-CSRF token. The attacker can deceive an authenticated customer into clicking the harmful link and thus place an order without the customer's awareness.	A01:2025 - Broken Access Control
5	<code>adminGetOrders()</code>	Missing Authentication and Authorization. The administrative interface gives access to customer orders but no security measures are in place. As a result, any unauthorized user can view confidential information regarding the admin user that has accessed this interfaces such as clients' names, contacts, the amount of the orders and different kinds of personal data.	A01:2025 – Broken Access Control

[5 Marks]

- ii. From Appendix B (*composer.json*), identify the three (3) third-party libraries that contain known vulnerabilities. For each library, state the installed version, the CVE identifier, the CVSS v3.1 Base Score, the NVD severity rating, and the vulnerability type. You must verify each CVE from the NVD at <https://nvd.nist.gov>.

1. phpmailer/phpmailer

 CVE-2016-10033 Detail

Description

The mailSend function in the isMail transport in PHPMailer before 5.2.18 might allow remote attackers to pass extra parameters to the mail command and consequently execute arbitrary code via a \" (backslash double quote) in a crafted Sender property.

Metrics CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

 NIST: NVD	Base Score: 9.8 CRITICAL	Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
ADP: CISA-ADP	Base Score: 9.8 CRITICAL	Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

2. guzzlehttp/guzzle

 CVE-2022-31090 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

Guzzle, an extensible PHP HTTP client. `Authorization` headers on requests are sensitive information. In affected versions when using our Curl handler, it is possible to use the `CURLOPT\_HTTPAUTH` option to specify an `Authorization` header. On making a request which responds with a redirect to a URL with a different origin (change in host, scheme or port), if we choose to follow it, we should remove the `CURLOPT\_HTTPAUTH` option before continuing, stopping curl from appending the `Authorization` header to the new request. Affected Guzzle 7 users should upgrade to Guzzle 7.4.5 as soon as possible. Affected users using any earlier series of Guzzle should upgrade to Guzzle 6.5.8 or 7.4.5. Note that a partial fix was implemented in Guzzle 7.4.2, where a change in host would trigger removal of the curl-added Authorization header, however this earlier fix did not cover change in scheme or change in port. If you do not require or expect redirects to be followed, one should simply disable redirects all together. Alternatively, one can specify to use the Guzzle steam handler backend, rather than curl.

Metrics CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

 CNA: GitHub, Inc.	Base Score: 7.7 HIGH	Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N
--	-----------------------------	---

3. league/flysystem

CVE-2021-32708 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

Flysystem is an open source file storage library for PHP. The whitespace normalisation using in 1.x and 2.x removes any unicode whitespace. Under certain specific conditions this could potentially allow a malicious user to execute code remotely. The conditions are: A user is allowed to supply the path or filename of an uploaded file, the supplied path or filename is not checked against unicode chars, the supplied pathname checked against an extension deny-list, not an allow-list, the supplied path or filename contains a unicode whitespace char in the extension, the uploaded file is stored in a directory that allows PHP code to be executed. Given these conditions are met a user can upload and execute arbitrary code on the system under attack. The unicode whitespace removal has been replaced with a rejection (exception). For 1.x users, upgrade to 1.1.4. For 2.x users, upgrade to 2.1.1.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: 8.1 HIGH

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H



CNA: GitHub, Inc.

Base Score: 9.8 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

No	Third-Party Library	Installed Version	CVE ID	CVSS v3.1 Base Score	NVD Severity	Vulnerability Type
1.	phpmailer/phpmailer	5.2.16	CVE-2016-10033	9.8	Critical	Remote code execution through mail command injection
2.	guzzlehttp/guzzle	6.5.5	CVE-2022-31090	7.7	High	Information disclosure and credential leakage
3.	league/flysystem	1.1.3	CVE-2021-32708	8.1	High	Race condition and remote code execution via unicode whitespace normalisation

[5 Marks]

- b) For each of the three CVEs identified in Question 1(a)(ii), analyse the CVSS v3.1 Base Score components as published in the NVD. Your analysis must address the Attack Vector, Attack Complexity, Privileges Required, and Confidentiality/Integrity/Availability Impact metrics for each CVE, and explain what each metric value means in the specific context of the QuickDeliver food delivery platform.

- **CVE-2016-10033 - PHPMailer 5.2.16 (Critical : 9.8)**

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Metric	Value	Meaning in the context of QuickDeliver
Attack Vector (AV)	Network (N)	This vulnerability can be exploited over the internet. An attacker can carry out the attack without being inside the QuickDeliver data centre. They can send a malicious HTTP POST request to <code>sendConfirmationEmail()</code> endpoint from any location across the world.
Attack Complexity (AC)	Low (L)	The attack can be executed without the need for technical physical, environmental, or conditions of system. The attacker just needs to insert a backslash double quote (") in the <code>sender_name</code> parameter. No complex knowledge regarding server configuration is required for successful execution.
Privileges Required (PR)	None (N)	The <code>sendConfirmationEmail()</code> method is triggered using a public-facing dispatcher (case 'email'). The attacker does not require a customer login, an admin session or any previous authentication to call this method.
Confidentiality Impact (C)	High (H)	Successful exploitation leads to arbitrary command execution on the server. An attacker can read the entire QuickDeliver database which include customer names, phones, addresses, order history and the payment API key stored in the source code.
Integrity Impact (I)	High (H)	The attacker can change orders, modify customer details, change restaurant information, and change payment slips. They might also be able to change the

		configuration files of the system to transfer money into their own accounts.
Availability Impact (A)	High (H)	The attacker can erase important system files, shut the web server down, and impair the entire food delivery service, causing customers and restaurants not to be able to place and receive orders.

- **CVE-2022-31090: Guzzle 6.5.5 (High -7.7)**

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N

Metric	Value	Meaning in the Context of QuickDeliver
Attack Vector (AV)	Network (N)	This vulnerability is exploited when the Guzzle HTTP client accepts a redirect to a malicious resource. This server could be situated anywhere on the web.
Attack Complexity (AC)	Low (L)	Any attack involves obtaining control over a third-party server able to produce a particular redirect. This type of attack is trivial and doesn't require any sophisticated timing techniques or misuse of resources.
Privileges Required (PR)	Low (L)	The attacker should possess influence over the destinations of the Guzzle requests which may happen through hacking a legitimate API of some third party that QuickDeliver employs. For example, a payment processor.
Confidentiality Impact (C)	High (H)	The Authorization header has leaked the Payment API key (pgw_live_sk_...) to the perpetrator's server which leads to the exposure of the actual secret payment gateway key. As a result, the attacker can process illegitimate payments.
Integrity Impact (I)	None (N)	This specific vulnerability gives the attacker no chance to manipulate or spoil any information on the QuickDeliver server.
Availability Impact (A)	None (N)	This specific vulnerability does not interfere with the availability of the QuickDeliver platform.

- **CVE-2021-32708 - League Flysystem 1.1.3 (High: 8.1)**

CVSS Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Metric	Value	Meaning in the Context of QuickDeliver
Attack Vector (AV)	Network (N)	This vulnerability makes use of the upload functionality through the file upload (uploadReceipt()) that is accessible on the network through POST requests.
Attack Complexity (AC)	High (H)	For this exploit to work effectively, the conditions must be all true at the same time. Firstly, the attacker should be able to provide the name of the file. Secondly, the name should include the unicode whitespace characters in the extension. Thirdly, the server must verify the extension by using the denylist. Last but not least, the upload directory must be available on the web and should permit execution of PHP. While it is possible, it is certainly harder than the PHPMailer.
Privileges Required (PR)	None (N)	The uploadReceipt() function is called through a case 'upload' dispatcher without an authentication requirement meaning that everyone can upload files.
Confidentiality Impact (C)	High (H)	If everything works correctly, the attacker gains the capability of running any code of their desire on the server. They will have access to the entire database (quickdeliver schema) and get the MySQL root login credentials as well as extract all customer PII.
Integrity Impact (I)	High (H)	The attacker can overwrite with the uploaded bill files, change the configuration files as well as add spam entries to the database.
Availability Impact (A)	High (H)	The attacker can disrupt the receipts folder, make the server crash down, or cause the application to not work.

[15 Marks]

- c) Evaluate the combined risk created by the SAST vulnerabilities (from Appendix A) and the SCA vulnerabilities (from Appendix B). Your evaluation must address the following;
- Most dangerous combined attack chain by selecting one SAST vulnerability and one SCA vulnerability that an attacker would exploit in sequence.

The most dangerous attack chain combines a SAST vulnerability (from Appendix A) as the reconnaissance step and SCA vulnerability (from Appendix B) to get Remote Code Execution (RCE). I have identified two possible attack chains with the most important one being the most efficient and stealthy attack.

Component	Selected Vulnerability	Rationale
SAST (Appendix A)	Missing Authentication and Authorization adminGetOrders()	Exposes the complete customer databases such as names, phones, addresses, order IDs, totals to idles who know nothing about hacking. One just must write ?action=admin to see a table with all data.
SCA (Appendix B)	CVE-2016-10033- PHPMailer 5.2.16	Allows arbitrary command execution via sendConfirmationEmail(). It works with parameters that are confirmed by the admin panel and meaningful for the company thus avoiding crashing the app.

In Step 1, the hacker conducts passive reconnaissance by browsing <https://quickdeliver.com.my/?action=admin>. The server does not require authentication, allowing for the retrieval of an HTML table consisting of order id, customer name, phone number, address, and amount for all transactions made on the system. The attacker can now gather enough verified data for further exploitation to be masked as regular data sent by the application.

In Step 2, the hacker collects the data and extracts a real order_id and the amount from it. The order_id and amount are required to supply correct parameters to the

sendConfirmationEmail() function in order to avoid errors in the application since those are the values from the admin panel.

In Step 3, the attacker makes a malicious POST request to the ?action=email page using the extracted parameters and a specifically created payload for sender_mail. The backslash double quote (\") escapes the mail command as well as the options (-O) QueueDirectory that refers to the mail queue directory and -X that refers to the mail output file. As a result, a PHP web shell will be written into the root directory of the website.

During Step 4, the server receives the request, and PHPMailer invokes the mail() binary, providing the proper arguments. The mail function emits the email log output to /var/www/html/shell.php. At this point, the attacker can go to <https://quickdeliver.com.my/shell.php> and run any PHP code they want on the server.

In Step 5, with full Remote Code Execution, the attacker views quickdeliver.php to extract the MySQL root password (QkDel!v3r2025) and the Payment API key (pgw_live_sk...). The attacker downloads the customer information and orders, runs ransomware, defaces the website and utilizes the hacked server as the first step to infiltrate QuickDeliver's corporate infrastructure.

There are many strong points that make this attack chain one of the most dangerous attack methods. For conducting reconnaissance, no special technical skills are required since the only action that needs to be executed is calling the ?action=admin function which results in receiving formatted data of production quality without making any malicious request. This is significantly stealthier than SQL injection since there is a chance that the attack is detected by web application firewalls or intrusion detection systems. Another strong trait of this attack type is the quality of the data that got collected, and now the hacker wants to get the exact real identities and sums in order that RCE request will not be rejected due to the wrong parameters and therefore the malicious actions cannot be distinguished from legitimate application traffic. The attacker compromises the system in a matter of seconds as the only actions that need to be taken are merely two HTTP requests. Last but not the least, the business impact of this attack can be called disastrous since the hacker has access not only to the secrets of customers' PII information such as names, contacts, addresses and order

history but also to the whole server giving him/her an opportunity to commit blackmail, steal identities, commit financial fraud, and destroy the whole food delivery platform.

- ii. The PDPA 2024 implication for QuickDeliver if this attack chain is successfully executed.

Malaysia's Personal Data Protection Act of 2010 (PDPA) creates numerous responsibilities for data controllers and what has been dealt with in the above chain of attacks leads to a major data breach involving all customers of QuickDeliver. The breach will reveal sensitive personal information, such as customers' full names, mobile numbers, addresses, order history, information on spending habits and payment gateway API key and MySQL root password, that have been put into the code, thus breaking several PDPA principles. As for Principle 3 (Security) where in QuickDeliver has not maintained adequate measures to protect personal data, the proof can be found in such details as unpatched vulnerability in PHP mailer, absence of authentication on the admin panel, and use of hardcoded credentials. It means that the PDPA commissioner can impose a fine of up to RM 1 million for each breach that has been done according to section 25 (2) of the PDPA. As for Principle 7 (Access), it indicates that unauthorized individuals have illegally accessed and taken customers' personal data without their consent, prompting QuickDeliver to be responsible for any financial losses or feeling of distress incurred by customers.

The requirement to notify a violation under Section 5 of the PDPA (Amendment) 2024 means that notice must be given to the Commissioner and the affected data subjects within 72 hours of the verification of the breach. The fine for not notifying can reach RM 300,000. Violations of this nature usually invite a class action lawsuit from the customers affected by the violation. The legal costs of the lawsuit can exceed RM 5 million once legal expenses are calculated. In addition, because of its violation, QuickDeliver would find itself on the PDPA Watchlist and thus would need to undergo yearly security checks for the following five years costing about RM 500,000. Customers would also lose trust in the ability of QuickDeliver to secure their personal data leading to losses of revenue that can exceed RM 10 million over three years because of customer churn. The total financial effect from the breach is nearly RM 16.8 million excluding the expenses taking into account the lost reputation and loss of market share.

- iii. Which vulnerability would you classify as the single most urgent remediation and justify using CVSS evidence.

The most urgent vulnerability in need of immediate attention is CVE-2016-10033 for PHPMailer version 5.2.16, with a CVSS v3.1 Base Score of 9.8 (CRITICAL) and a vector of CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H. CVE-2016-10033 takes precedence over all other vulnerabilities for the following seven reasons based on CVSS evidence.

First, this vulnerability allows for Direct Remote Code Execution (RCE) which gives hackers the ability to execute any commands on the server. Nothing is more dire in the world of cybersecurity than this attack vector; while attacks like SQL Injection only allow the attacker to access sensitive information or Missing Admin Auth may help the perpetrator steal data, RCE allows the assailant to introduce malware, gain access to employees' computers and run system commands.

Second, the Attack Complexity (AC) is LOW, meaning exploitation is a walk in the park. Hackers can publicly access exploitation codes and there are no necessary conditions for a successful attack in contrast to the complexities of CVE-2021-32708 League/ Flysystem, which require specific terms such as unicode whitespace handling and allowlist bypassing, which complicate the hacking process.

Third, the Privileges Required (PR) is NONE making it possible for attacker to access the sendConfirmationEmail() function even if they are not authenticated unlike the case with CVE-2022-31090 Guzzle which requires some minimum privileges to hack.

The vulnerability has a Complete CIA Impact with high ratings for all three categories of Confidentiality, Integrity, and Availability. It indicates that a breach allows attackers to read, change, or completely remove any piece of information from the server, impacting all three principles of security. The League/ Flysystem CVE impacts the three categories, but it has high attack complexity, making it less dangerous. The CVE related to Guzzle does not impact Integrity and Availability at all and the SAST

vulnerabilities do not impact many CIA categories either the impact of SQL Injection on Availability is low while Missing Admin Auth has no impact on Integrity or Availability.

Fifth, CVE-2016-10033 has been around since 2016, making it popular among red-team experts, the issue can be called great. Nowadays, CVE-2016-10033 is being exploited manually and attackers are constantly looking for web apps that use vulnerable PHPMailer versions to reduce the likelihood of detection. Moreover, many people are aware of attacks based on this vulnerability, so many proof-of-concept exploits exist and only very few minimal changes are needed for any of them. As shown in the example of the attack chain, this vulnerability can be used in combination with pretty much anything for achieving complete server compromise.

Based on this evidence, the immediate recommended steps mentioned are to update PHPMailer to version 5.2.18 or v6.0+ in 24 hours and if patching is not performed within this time frame, disable the email dispatcher route temporarily or to use strict sanitisation which prohibits the presence of backslash double quotes to perform a complete server scan within 48 hours to look for the signs of penetration, and to change and review all credentials that could have been compromised like MySQL root password, SMTP password, and Payment API key within 72 hours. The change at the code level should replace the unsafe unsanitized usage with correct validation.

[20 Marks]

- d) Design a Vulnerability Risk Register for QuickDeliver Sdn. Bhd. covering all five SAST findings from Question 1(a)(i) and all three SCA findings from Question 1(a)(ii). The register must be suitable for presentation to QuickDeliver management. Do not include any source code.

VULNERABILITY RISK REGISTER

Company: QuickDeliver Sdn. Bhd.

Application: QuickDeliver Food Delivery Platform

Assessment Date: 7–10 July 2026

Risk Assessment Methodology: CVSS v3.1 + Business Impact

EXECUTIVE SUMMARY FOR MANAGEMENT

RISK ID	Source	Affected Component	Vulnerability Description	OWASP	CVSS	Priority	Likelihood	Risk Rating	Business Impact
V1	SAST	Global Scope and sendConfirmationEmail()	Hardcoded Secrets- MySQL password, Payment API key, SMTP password in plaintext.	A02	N/A	P1	High	CRITICAL	Full DB compromise, financial theft and email hijacking.
V2	SAST	searchRestaurants()	SQL Injection – \$_GET['keyword'] concatenated into query.	A05	8.8	P1	High	CRITICAL	Attacker dumps all customer PII such as names, phones, addresses, orders.
V3	SAST	searchRestaurants()	Reflected XSS – user input echoed without HTML encoding.	A05	6.1	P2	High	MEDIUM	Session hijacking, defacement and phishing redirects.
V4	SAST	placeOrder()	Missing CSRF token – fraudulent orders can be submitted on behalf of authenticated users.	A01	6.5	P2	High	HIGH	Financial losses from unauthorised charges and chargebacks.
V5	SAST	adminGetOrders()	Missing Authentication – admin panel accessible to any unauthenticated user.	A01	7.5	P1	Critical	CRITICAL	Mass exposure of customer names, phones, addresses, order totals to the public.
V6	SCA	phpmailer/phpmailer (v5.2.16)	CVE-2016-10033 – Remote Code Execution via mail command injection in sender_name.	A05	9.8	P0	High	CRITICAL	Full server takeover and arbitrary command execution.
V7	SCA	guzzlehttp/guzzle (v6.5.5)	CVE-2022-31090 – Payment	A02	7.7	P2	Medium	HIGH	Live Payment API key

			Authorization header leaks to malicious servers during redirects.						exposure enables fraudulent charges.
V8	SCA	league/flysystem (v1.1.3)	CVE-2021-32708 – RCE via unicode whitespace manipulation in uploaded filenames.	A06	8.1	P1	Low	CRITICAL	Server takeover via malicious file upload bypass.

REMEDATION LOOKUP TABLE

ID	Recommended Remediation
V1	Transition all sensitive information to environmental variables or a specialized secrets management application. Change the DB password, payment API secret codes, and SMTP password right now.
V2	Utilize parameterized queries for each DB interaction to maintain a division between SQL logic and user input.
V3	Perform encoding for every user-supplied value prior to rendering it in a web page to avoid script injections.
V4	Use anti-forgery tokens for every state-changing call and set up proper attributes for cookies to block unauthorized transactions.
V5	Obligate role-based access control and session-dependent authentication for all administrative routes and functions.
V6	Upgrade PHPMailer to 5.2.18 or 6.0 or any higher version. If an immediate patch is not possible, do strict input validation on the sender's name field to ensure that special characters are not allowed.
V7	Upgrade Guzzle to 6.5.8 version or 7.4.5 or any higher version. Disable automatic HTTP redirect following for secure payment APIs.
V8	Upgrade Flysystem to 1.1.4 or 2.1.1 or any higher version. Implement strict filename sanitization and allowlisting for any files uploaded.

EXECUTIVE SUMMARY FOR MANAGEMENT

Metric	Value
Total Findings	8 (5 Code-level and 3 Library-level)
Critical (P0)	1 – V6 (CVE-2016-10033) patch within 24 hours.
High (P1)	4 findings (V1, V2, V5, V8) remediate within 72 hours.
Medium (P2)	3 findings (V3, V4, V7) remediate within 1 and 2 weeks.

Top 3 Critical Risks for Board Attention:

V6 (P0) – Direct Remote Code Execution (CVSS 9.8). Patch immediately to prevent full server takeover.

V1 (P1) – Live DB password and payment key in plaintext. Any source code leaks total compromise.

V5 (P1) – Admin panel is wide open. This violates PDPA Principle 3 and exposes to RM 1 million fines.

Recommended Action:

Authorise a 72-hour security sprint to remediate all P0 and P1 items before the public launch. Conduct a penetration test post-remediation.

[20 Marks]

QUESTION 2 [35 Marks]

You are required to conduct a formal dual-tool security assessment of the QuickDeliver application using both Semgrep (SAST) and OWASP Dependency-Check (SCA). Both tools must be executed against the materials in Appendix A and Appendix B respectively.

- a) Install and execute both tools as instructed below. Document each step using screenshots and complete the Dual Scan Evidence Form.

Tool 1: Semgrep (SAST)

Save Appendix A as *quickdeliver.php* and run the following commands:

```
1. pip install semgrep
2. semgrep --config=p/owasp-top-ten quickdeliver.php --output semgrep_results.txt
3. semgrep --config=p/secrets quickdeliver.php --output semgrep_secrets.txt
```

Tool 2: OWASP Dependency-Check (SCA)

Save Appendix B as *composer.json* and run the following commands:

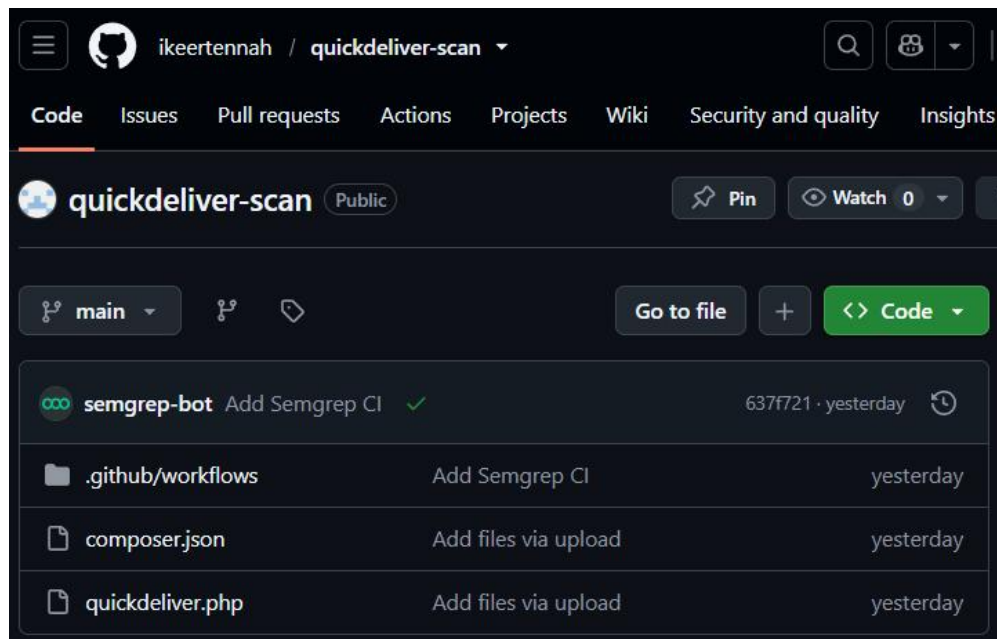
```
wget https://github.com/jeremylong/DependencyCheck/releases/download/v9.0.7/dependency-check-9.0.7-release.zip
unzip dependency-check-9.0.7-release.zip
./dependency-check/bin/dependency-check.sh \
  --project "QuickDeliver" --scan composer.json \
  --format HTML --format JSON --out dependency-check-report/
```

Tool 1: Semgrep (SAST)

Run the commands inside a GitHub Actions, then push results to the Semgrep website. This gives you terminal screenshots and the dashboard.

- Step 1: Set up your GitHub Repository

Create a new public repository on GitHub named as quickdeliver-scan and upload quickdeliver.php and composer.json into the root folder.



- Step 2: Run the scans inside GitHub codespaces. A browser-based visual studio code terminal will open. Run the install semgrep (SAST) and the SAST scan.

```

PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS
^[[200~pip install semgrep^[[201~@ikeertennah →/workspaces/quickdeliver-scan (main) $ pip install semgrep
collecting semgrep
  Downloading semgrep-1.168.0-cp310.cp311.cp312.cp313.cp314.py310.py311.py312.py313.py314-none-manylinux_2_34_x86_64.w
hl.metadata (22 kB)
Requirement already satisfied: attrs>=21.3 in /home/codespace/.local/lib/python3.12/site-packages (from semgrep) (25.4
.0)
collecting boltons>=21.0 (from semgrep)
  Downloading boltons-21.0.0-py2.py3-none-any.whl.metadata (1.5 kB)
collecting click-option-group>=0.5 (from semgrep)
  Downloading click_option_group-0.5.9-py3-none-any.whl.metadata (5.8 kB)
collecting click>=8.1.8 (from semgrep)
  Downloading click-8.1.8-py3-none-any.whl.metadata (2.3 kB)
Requirement already satisfied: colorama>=0.4.0 in /home/codespace/.local/lib/python3.12/site-packages (from semgrep) (
0.4.6)
collecting exceptiongroup>=1.2.0 (from semgrep)
  Downloading exceptiongroup-1.2.2-py3-none-any.whl.metadata (6.6 kB)
collecting glom>=23.3 (from semgrep)
  Downloading glom-25.12.0-py3-none-any.whl.metadata (5.2 kB)
collecting jsonschema>=4.25.1 (from semgrep)
  Downloading jsonschema-4.25.1-py3-none-any.whl.metadata (7.6 kB)
collecting mcp>=1.23.3 (from semgrep)
  Downloading mcp-1.23.3-py3-none-any.whl.metadata (89 kB)
collecting opentelemetry-api>=1.37.0 (from semgrep)
  Downloading opentelemetry_api-1.37.0-py3-none-any.whl.metadata (1.5 kB)
collecting opentelemetry-sdk>=1.37.0 (from semgrep)
  Downloading opentelemetry_sdk-1.37.0-py3-none-any.whl.metadata (1.5 kB)
collecting opentelemetry-exporter-otlp-proto-http>=1.37.0 (from semgrep)

```



```

@likeertennah →/workspaces/quickdeliver-scan (main) $ semgrep --config-p/owasp-top-ten quickdeliver.php --output semgrep_results.txt
Semgrep CLI

Scanning 1 file (only git-tracked) with 560 Code rules:

CODE RULES
┌──────────┬───┬───┬──────────┬───┐
│ Language │ Rules │ Files │ Origin │ Rules │
├──────────┴───┴───┴──────────┴───┤
│ php │ 22 │ 1 │ Community │ 560 │
├──────────┬───┬───┬──────────┬───┤
│ <multilang> │ 5 │ 1 │ │ │
└──────────┴───┴───┴──────────┴───┘

SUPPLY CHAIN RULES

Sign in with "semgrep login" and run
"semgrep ci" to find dependency vulnerabilities and
advanced cross-file findings.

PROGRESS
100% 0:00:00

@likeertennah →/workspaces/quickdeliver-scan (main) $ semgrep --config-p/secrets quickdeliver.php --output semgrep_secrets.txt
Semgrep CLI

Scanning 1 file (only git-tracked) with 52 Code rules:

CODE RULES
Scanning 1 file with 36 <multilang> rules.

SUPPLY CHAIN RULES

Sign in with "semgrep login" and run
"semgrep ci" to find dependency vulnerabilities and
advanced cross-file findings.

PROGRESS
100% 0:00:00

Scan Summary
Scan completed successfully.
• Findings: 0 (0 blocking)
• Rules run: 36
• Targets scanned: 1
• Parsed lines: ~100.0%
• No ignore information available
Ran 36 rules on 1 file: 0 findings.
Missed out on 218 pro rules since you aren't logged in!
Supercharge Semgrep OSS when you create a free account at https://sg.run/rules.
(need more rules? "semgrep login" for additional free Semgrep Registry rules)

```

- Step 3: Open the output of semgrep_result.txt that produce after running the command.

```

semgrep_results.txt x
semgrep_results.txt
3
4 2 Code Findings
5
6
7 esc[36mesc[22mesc[24m quickdeliver.phpesc[0m
8 >>> %1mphp.lang.security.injection.tainted-sql-string.tainted-sql-string%0m
9 esc[31mesc[1mesc[24m(( Blocking ))esc[0m
10 User data flows into this manually-constructed SQL string. User data can be safely inserted into SQL
11 strings using prepared statements or an object-relational mapper (ORM). Manually-constructed SQL
12 strings is a possible indicator of SQL injection, which could let an attacker steal or manipulate
13 data from the database. Instead, use prepared statements ('$mysqli->prepare("INSERT INTO test(id,
14 label) VALUES (?, ?)");') or a safe library.
15 Details: https://sg.run/lzyg
16
17 25| $sql = "SELECT id, name, cuisine, rating FROM restaurants"
18 26| ." WHERE name LIKE '%" . $keyword . "%'";
19
20 >>> %1mphp.lang.security.injection.echoed-request.echoed-request%0m
21 esc[31mesc[1mesc[24m(( Blocking ))esc[0m
22 `Echo'ing user input risks cross-site scripting vulnerability. You should use `htmlentities()' when
23 showing data to users.
24 Details: https://sg.run/Bqqb
25
26 esc[32m>>>| Autofix ▶ esc[0mecho htmlentities("<h3>Results for: " . $_GET['keyword'] . "</h3>");
27 31| echo "<h3>Results for: " . $_GET['keyword'] . "</h3>";
28

```

- Step 4: Connect to Semgrep website

☐	Project	Last scan	Code findings	Supply Chain findings	Scanned dependencies	Tags
☐	ikeertennah/quickdeliver-scan	7 hours ago	5	0	0	

Step 1: Install dependencycheck version 12.2.2.

- [illegible]

- ```

@ikeertennah → /workspaces/quickdeliver-scan (main) $ unzip dependency-check-12.2.2-release.zip
Archive: dependency-check-12.2.2-release.zip
 creating: dependency-check/
 creating: dependency-check/bin/
 creating: dependency-check/lib/
 creating: dependency-check/plugins/
 creating: dependency-check/licenses/
 creating: dependency-check/licenses/commons-cli/
 inflating: dependency-check/bin/completion-for-dependency-check.sh
 inflating: dependency-check/bin/dependency-check.sh
 inflating: dependency-check/bin/dependency-check.bat
 inflating: dependency-check/lib/aho-corasick-double-array-trie-1.2.3.jar
 inflating: dependency-check/lib/art-1.10.17.jar
 inflating: dependency-check/lib/commons-cli-1.11.0.jar
 inflating: dependency-check/lib/commons-codec-1.22.0.jar
 inflating: dependency-check/lib/commons-collections4-4.5.0.jar
 inflating: dependency-check/lib/commons-compress-1.27.1.jar
 inflating: dependency-check/lib/commons-dbcp2-2.14.0.jar
 inflating: dependency-check/lib/commons-io-2.22.0.jar
 inflating: dependency-check/lib/commons-jcs3-core-3.2.1.jar
 inflating: dependency-check/lib/commons-lang3-3.20.0.jar
 inflating: dependency-check/lib/commons-pool2-2.13.0.jar
 inflating: dependency-check/lib/commons-text-1.15.0.jar
 inflating: dependency-check/lib/commons-validator-1.10.1.jar
 inflating: dependency-check/lib/compiler-0.9.6.jar
 inflating: dependency-check/lib/cpe-parser-3.0.1.jar
 inflating: dependency-check/lib/dependency-check-cli-12.2.2.jar
 inflating: dependency-check/lib/dependency-check-core-12.2.2.jar
 inflating: dependency-check/lib/dependency-check-utils-12.2.2.jar

```

- ```

#lsb_release -a
#packages/gunicorn-16.0n (main) # sudo apt-get update 86 sudo apt-get install php php-abstract -y
Get:1 https://packages.microsoft.com/repos/microsoft-ubuntu-noble-prod noble InRelease [3600 B]
Get:2 https://packages.microsoft.com/repos/microsoft-ubuntu-noble-prod noble/main amd64 Packages [789 kB]
Get:3 https://packages.microsoft.com/repos/microsoft-ubuntu-noble-prod noble/main all Packages [643 B]
Get:4 http://archive.ubuntu.com/ubuntu noble InRelease [256 kB]
Get:5 http://security.ubuntu.com/ubuntu noble-security InRelease [126 kB]
Get:6 http://security.ubuntu.com/ubuntu noble-security/main amd64 Packages [1022 kB]
Get:7 http://archive.ubuntu.com/ubuntu noble-updates InRelease [126 kB]
Get:8 http://archive.ubuntu.com/ubuntu noble-backports InRelease [126 kB]
Get:9 http://security.ubuntu.com/ubuntu noble-security/multiverse amd64 Packages [43.8 kB]
Get:10 http://security.ubuntu.com/ubuntu noble-security/restricted amd64 Packages [1417 kB]
Get:11 http://archive.ubuntu.com/ubuntu noble/multiverse amd64 Packages [331 kB]
Get:12 http://security.ubuntu.com/ubuntu noble-security/universe amd64 Packages [1490 kB]
Get:13 http://archive.ubuntu.com/ubuntu noble/restricted amd64 Packages [117 kB]
Get:14 http://archive.ubuntu.com/ubuntu noble/universe amd64 Packages [15.3 MB]
Get:15 http://archive.ubuntu.com/ubuntu noble/main amd64 Packages [1180 kB]
Get:16 http://archive.ubuntu.com/ubuntu noble-updates/restricted amd64 Packages [1490 kB]
Get:17 http://archive.ubuntu.com/ubuntu noble-updates/universe amd64 Packages [2212 kB]
Get:18 http://archive.ubuntu.com/ubuntu noble-updates/main amd64 Packages [1343 kB]
Get:19 http://archive.ubuntu.com/ubuntu noble-updates/multiverse amd64 Packages [49.5 kB]
Get:20 http://archive.ubuntu.com/ubuntu noble-backports/multiverse amd64 Packages [674 B]
Get:21 http://archive.ubuntu.com/ubuntu noble-backports/universe amd64 Packages [15.9 kB]
Get:22 http://archive.ubuntu.com/ubuntu noble-backports/main amd64 Packages [48.9 kB]
Fetched 31.5 MB in 8s (4146 kB/s)
Reading package lists... Done
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  apache2-common bin apache2-data apache2-utils libapache2-mod-php8.3 libapr1t64 libaprutil1-dbd-sqlite3 libaprutil1-ldap libaprutil1t64 liblua5.4-0
  php-common php8.3-cli php8.3-common php8.3-mbstring php8.3-opcache php8.3-readline ssl-cert

```

- 18

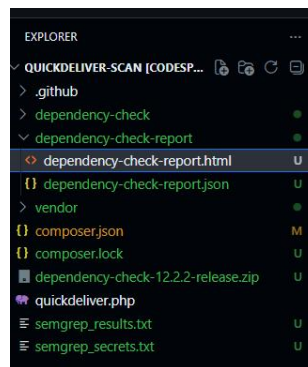
```
@likeertennah →/workspaces/quickdeliver-scan (main) $ ./dependency-check/bin/dependency-check.sh --project "QuickDeliver" --scan
composer.json --format HTML --format JSON --out dependency-check-report/ --nvdApiKey 563707be-6f8b-4b36-8c57-835bf68c141d
[INFO] Completed processing batch 1/1 (100%) in 11,406ms
[INFO] Skipping Known Exploited Vulnerabilities update check since last check was within 24 hours.
[INFO] Begin database defrag
[INFO] End database defrag (18771 ms)
[INFO] Check for updates complete (131652 ms)
[INFO]

Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false n
egatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for
use in an AS IS condition, and there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of
the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for a
ny damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report
.

About ODC: https://dependency-check.github.io/DependencyCheck/general/internals.html
False Positives: https://dependency-check.github.io/DependencyCheck/general/suppression.html

[INFO] Analysis Started
[INFO] Finished File Name Analyzer (0 seconds)
[INFO] Finished Dependency Merging Analyzer (0 seconds)
[INFO] Finished Hint Analyzer (0 seconds)
[INFO] Created CPE Index (3 seconds)
[INFO] Finished CPE Analyzer (3 seconds)
[INFO] Finished False Positive Analyzer (0 seconds)
[INFO] Finished NVD CVE Analyzer (0 seconds)
[WARN] Sonatype OSS Index Analyzer disabled due to missing credentials. Authentication with token is now required, and OSS Index
is migrating to Sonatype Guide. See https://dependency-check.github.io/DependencyCheck/analyzers/oss-index-analyzer.html for mo
re information on authentication with Sonatype Guide OSS Index.
[INFO] Finished Vulnerability Suppression Analyzer (0 seconds)
[INFO] Finished Known Exploited Vulnerability Analyzer (0 seconds)
[INFO] Finished Dependency Bundling Analyzer (0 seconds)
[INFO] Finished Unused Suppression Rule Analyzer (0 seconds)
[INFO] Analysis Complete (4 seconds)
[INFO] Writing HTML report to: /workspaces/quickdeliver-scan/dependency-check-report/dependency-check-report.html
[INFO] Writing JSON report to: /workspaces/quickdeliver-scan/dependency-check-report/dependency-check-report.json
```

- Finally, the tool will show [INF] and it will download the NVD database using API key for few hours then right click dependency-check-report.html and download it. Open the file in browser and screenshot the details.



Dependency-Check Report

C:\Users\User\Dropbox\PC\Downloads\dependency-check-report%k20(4).html#1144_0faec238e3c4b8ea7aac244ddfc2f5e06c8b9d

FREE APA Citation... PERSAKA 21/22 C... PERSAKA 21/22 ... Newbies Camp CoW program AI PROJECT - Goo... GNETT - Google D... Virtu

DEPENDENCY-CHECK

Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report.

[How to read the report](#) | [Suppressing false positives](#) | [Getting Help: github issues](#)

Project: QuickDeliver

Scan Information ([show less](#)):

- dependency-check version: 12.2.2
- Report Generated On: Thu, 9 Jul 2026 01:14:26 GMT
- Dependencies Scanned: 263 (202 unique)
- Vulnerable Dependencies: 38
- Vulnerabilities Found: 305
- Vulnerabilities Suppressed: 0
- NVD API Last Checked: 2026-07-08T23:37:51Z
- NVD API Last Modified: 2026-07-08T23:16:54Z

Analysis Exceptions

Could not execute .NET AssemblyAnalyzer, is the dotnet 8.0 runtime or sdk installed?

Summary

Summary of Vulnerable Dependencies ([click to show all](#))

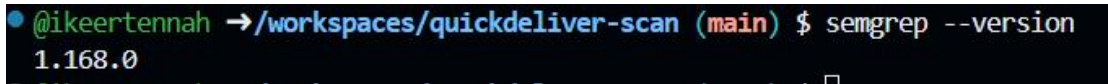
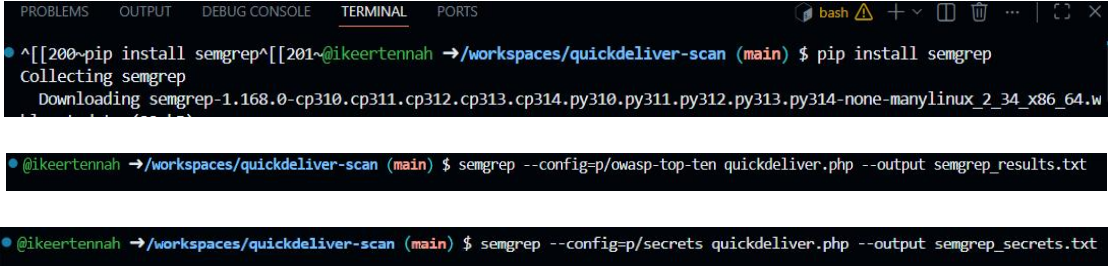
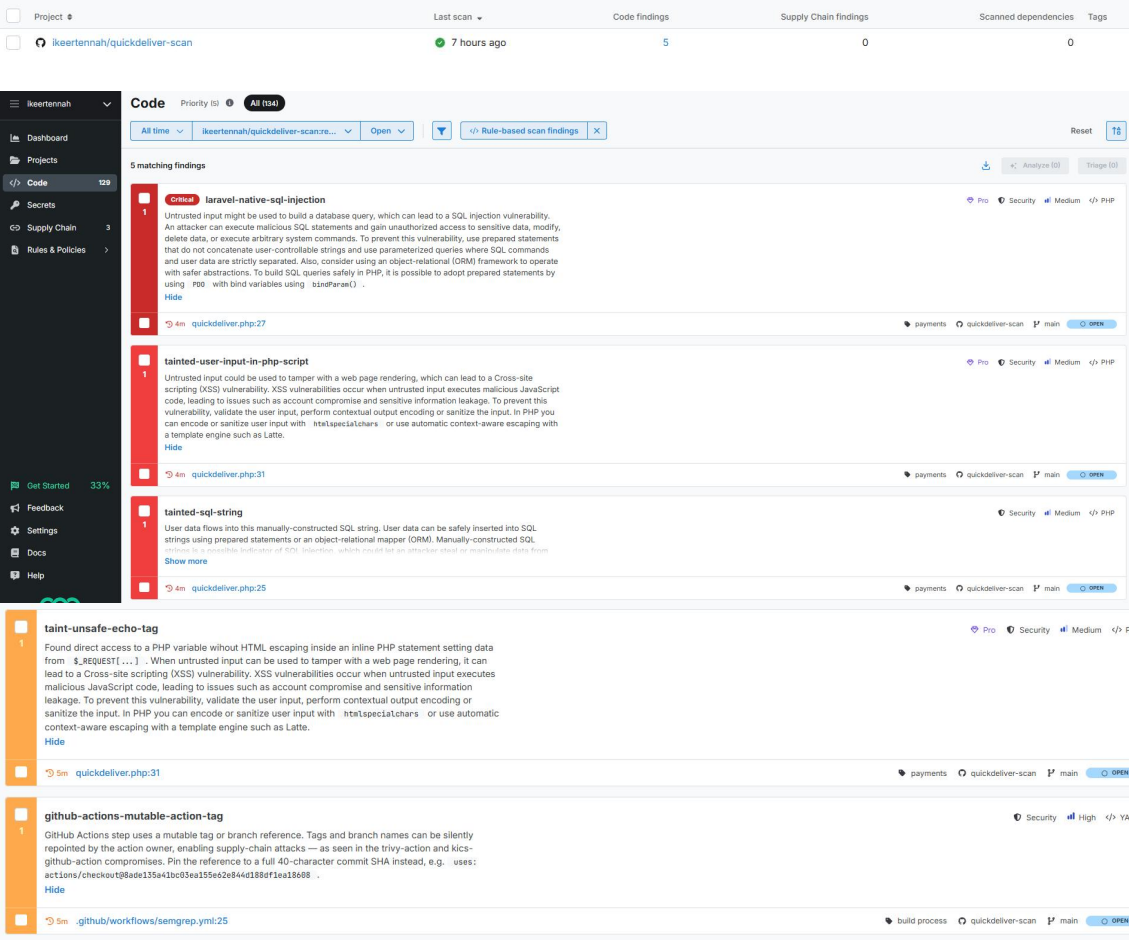
Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
code-unit-reverse-lookup@2.0.3	cpe:2.3.a:code-unit-reverse-lookup@2.0.3-*****	pkg-composer/sebastian/code-unit-reverse-lookup@2.0.3	MEDIUM	1	High	5
config@2.8.1	cpe:2.3.a:sensiolabs/symfony@2.8.1-*****	pkg-composer/symfony/config@2.8.1	CRITICAL	30	Highest	6
console@2.8.1	cpe:2.3.a:sensiolabs/symfony@2.8.1-*****	pkg-composer/symfony/console@2.8.1	CRITICAL	30	Highest	6
diff@1.4.1	cpe:2.3.a:diff-project/diff@1.4.1-*****	pkg-composer/sebastian/diff@1.4.1	CRITICAL	1	High	5
event-dispatcher@2.8.1	cpe:2.3.a:sensiolabs/symfony@2.8.1-*****	pkg-composer/symfony/event-dispatcher@2.8.1	CRITICAL	30	Highest	6
filesystem@3.0.1	cpe:2.3.a:sensiolabs/symfony@3.0.1-*****	pkg-composer/symfony/filesystem@3.0.1	CRITICAL	14	Highest	6
finder@2.8.1	cpe:2.3.a:finder-project/finder@2.8.1-*****	pkg-composer/symfony/finder@2.8.1	MEDIUM	1	High	6

- b) Examine the dual scan using the Semgrep and OWASP Dependency-Check SCA using the given evidence form in Section 1 and Section 2 accordingly.

Dual Scan Evidence Form. Students must complete all fields with screenshot evidence:

Section 1: Semgrep SAST Results

[7 marks]

Field	Student Entry
Semgrep version (screenshot)	
Scan command used	
Total findings count	

Findings table (Rule ID, Severity, File, Line, Description)

Code > #88190284

laravel-native-sql-injection OPEN

quickdeliver.php:27

Description

Untrusted input might be used to build a database query, which can lead to a SQL injection vulnerability. An attacker can execute malicious SQL statements and gain unauthorized access to sensitive data, modify, delete data, or execute arbitrary system commands. To prevent this vulnerability, use prepared statements that do not concatenate user-controllable strings and use parameterized queries where SQL commands and user data are strictly separated. Also, consider using an object-relational (ORM) framework to operate with safer abstractions. To build SQL queries safely in PHP, it is possible to adopt prepared statements by using `PDO` with bind variables using `bindParam()`.

References

Your code

Example code

quickdeliver.php

Line 23 Show

`$GET`

Line 23 Show

`$keyword`

Line 25 Show

`$sql`

Line 27 Show

`$sql`

quickdeliver.php:27

`< payments`

```
15 $db = new mysqli("localhost", "root", "QkDe1v3r2025", "quickdeliver");
16
17 // Payment API key hardcoded
18 $PAYMENT_API_KEY = "pgw_live_sk_Qk9OKZ3HwRtP7vLs2hCYbA4x3d";
19
20 // MODULE 1: Restaurant Search
21 function searchRestaurants() {
22     global $db;
23     $keyword = $_GET['keyword'];
24     // SQL Injection: unsanitised GET parameter in query
25     $sql = "SELECT id, name, cuisine, rating FROM restaurants
26     " . "WHERE name LIKE '%" . $keyword . "%'";
27     $result = $db->query($sql);
28     $data = [];
29     while ($row = $result->fetch_assoc()) { $data[] = $row; }
30     // Reflected XSS: user input echoed without encoding
31     echo "<Results for: " . $_GET['keyword'] . "</h3>";
32     return $data;
33 }
34
35 // MODULE 2: Place Order and Charge Payment
36 function placeOrder($customer_id, $restaurant_id, $total) {
37     global $db, $PAYMENT_API_KEY;
38     // No CSRF token validated
39     $client = new Client();
40     $response = $client->post("https://api.paygateway.com.my/charge", [
41         'headers' => ['Authorization' => 'bearer ' . $PAYMENT_API_KEY],
42         'json' => ['amount' => $total, 'currency' => 'MYR'];
43     ]);
```

RULE DETAILS

Critical severity

Medium confidence

CWE-89

laravel-native-sql-injection

FINDING DETAILS

17 minutes ago

ikeertannah/quickdeliver-scan

main

637721

by semgrep.dev on behalf of @ikeertannah

<support@semgrep.com>

Code > #88190282

tainted-user-input-in-php-script OPEN

quickdeliver.php:31

Description

Untrusted input could be used to tamper with a web page rendering, which can lead to a Cross-site scripting (XSS) vulnerability. XSS vulnerabilities occur when untrusted input executes malicious JavaScript code, leading to issues such as account compromise and sensitive information leakage. To prevent this vulnerability, validate the user input, perform contextual output encoding or sanitize the input. In PHP you can encode or sanitize user input with `htmlspecialchars()` or use automatic context-aware escaping with a template engine such as `Latte`.

References

Your code

Example code

quickdeliver.php

Line 31 Show

`$GET`

Line 31 Show

`$_GET['keyword']`

quickdeliver.php:31

`< payments`

```
19
20 // MODULE 1: Restaurant Search
21 function searchRestaurants() {
22     global $db;
23     $keyword = $_GET['keyword'];
24     // SQL Injection: unsanitised GET parameter in query
25     $sql = "SELECT id, name, cuisine, rating FROM restaurants
26     " . "WHERE name LIKE '%" . $keyword . "%'";
27     $result = $db->query($sql);
28     $data = [];
29     while ($row = $result->fetch_assoc()) { $data[] = $row; }
30     // Reflected XSS: user input echoed without encoding
31     echo "<Results for: " . $_GET['keyword'] . "</h3>";
32     return $data;
33 }
34
35 // MODULE 2: Place Order and Charge Payment
36 function placeOrder($customer_id, $restaurant_id, $total) {
37     global $db, $PAYMENT_API_KEY;
38     // No CSRF token validated
39     $client = new Client();
40     $response = $client->post("https://api.paygateway.com.my/charge", [
41         'headers' => ['Authorization' => 'bearer ' . $PAYMENT_API_KEY],
42         'json' => ['amount' => $total, 'currency' => 'MYR'];
43     ]);
```

RULE DETAILS

High severity

Medium confidence

CWE-79

tainted-user-input-in-php-script

FINDING DETAILS

16 minutes ago

ikeertannah/quickdeliver-scan

main

637721

by semgrep.dev on behalf of @ikeertannah

<support@semgrep.com>

Code > #88190283

tainted-sql-string OPEN

quickdeliver.php:25

Description

User data flows into this manually-constructed SQL string. User data can be safely inserted into SQL strings using prepared statements or an object-relational mapper (ORM). Manually-constructed SQL strings is a possible indicator of SQL injection, which could let an attacker steal or manipulate data from the database. Instead, use prepared statements (`$mysqli->prepare("INSERT INTO test(id, label) VALUES (?, ?);")`) or a safe library.

References

Your code

Example code

quickdeliver.php

Line 23 Show

`$GET`

Line 23 Show

`$keyword`

Line 25 Show

`"SELECT id, name, cuisine, rating FROM restaurants"`

quickdeliver.php:25

`< payments`

```
14 // Database configuration
15 $db = new mysqli("localhost", "root", "QkDe1v3r2025", "quickdeliver");
16
17 // Payment API key hardcoded
18 $PAYMENT_API_KEY = "pgw_live_sk_Qk9OKZ3HwRtP7vLs2hCYbA4x3d";
19
20 // MODULE 1: Restaurant Search
21 function searchRestaurants() {
22     global $db;
23     $keyword = $_GET['keyword'];
24     // SQL Injection: unsanitised GET parameter in query
25     $sql = "SELECT id, name, cuisine, rating FROM restaurants
26     " . "WHERE name LIKE '%" . $keyword . "%'";
27     $result = $db->query($sql);
28     $data = [];
29     while ($row = $result->fetch_assoc()) { $data[] = $row; }
30     // Reflected XSS: user input echoed without encoding
31     echo "<Results for: " . $_GET['keyword'] . "</h3>";
32     return $data;
33 }
34
35 // MODULE 2: Place Order and Charge Payment
36 function placeOrder($customer_id, $restaurant_id, $total) {
37     global $db, $PAYMENT_API_KEY;
38     // No CSRF token validated
39     $client = new Client();
40     $response = $client->post("https://api.paygateway.com.my/charge", [
41         'headers' => ['Authorization' => 'bearer ' . $PAYMENT_API_KEY],
42         'json' => ['amount' => $total, 'currency' => 'MYR'];
43     ]);
```

RULE DETAILS

High severity

Medium confidence

CWE-89

tainted-sql-string

FINDING DETAILS

13 minutes ago

ikeertannah/quickdeliver-scan

main

637721

by semgrep.dev on behalf of @ikeertannah

<support@semgrep.com>

Code > #88190280

taint-unsafe-echo-tag

OPEN

quickdeliver.php:31

Description

Found direct access to a PHP variable without HTML escaping inside an inline PHP statement setting data from `$_REQUEST[...]`. When untrusted input can be used to tamper with a web page rendering, it can lead to a Cross-site scripting (XSS) vulnerability. XSS vulnerabilities occur when untrusted input executes malicious JavaScript code, leading to issues such as account compromise and sensitive information leakage. To prevent this vulnerability, validate the user input, perform contextual output encoding or sanitize the input. In PHP you can encode or sanitize user input with `htmlspecialchars` or use automatic context-aware escaping with a template engine such as Latte.

References

Your code

Example code

quickdeliver.php

Line 31

Source

`$GET['keyword']`

Line 31

Diff

`echo "<h3>Results for: " . $_GET['keyword'] . "</h3>";`

quickdeliver.php:31

payments

```
19
20 // MODULE 1: Restaurant Search
21 function searchRestaurants() {
22     global $db;
23     $keyword = $_GET['keyword'];
24     // SQL Injection: unsanitised GET parameter in query
25     $sql = "SELECT id, name, cuisine, rating FROM restaurants"
26           "WHERE name LIKE '%" . $keyword . "%'";
27     $result = $db->query($sql);
28     $data = [];
29     while ($row = $result->fetch_assoc()) { $data[] = $row; }
30     // Reflected XSS: user input echoed without encoding
31     echo "<h3>Results for: " . $_GET['keyword'] . "</h3>";
32
33     return $data;
34 }
35
36 // MODULE 2: Place Order and Charge Payment
37 function placeOrder($customer_id, $restaurant_id, $total) {
38     global $db, $PAYMENT_API_KEY;
39     // No CSRF token validated
40     $client = new Client();
41     $response = $client->post('https://api.paygateway.com.my/charge', [
42         'headers' => ['Authorization' => 'Bearer ' . $PAYMENT_API_KEY],
43         'json' => ['amount' => $total, 'currency' => 'MYR']
44     ]);
45 }
```

RULE DETAILS

Medium severity

High confidence

CWE-79

taint-unsafe-echo-tag

FINDING DETAILS

14 minutes ago

ikeertennah/quickdeliver-scan

main

637f721

by semgrep.dev on behalf of @ikeertennah

<support@semgrep.com>

Code > #88190281

github-actions-mutable-action-tag

OPEN

.github/workflows/semgrep.yml:25

Description

GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks --- as seen in the trivy-action and kic3s-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@ade135e13c03ea156e2844d1880f1e18688`.

References

Your code

Example code

.github/workflows/semgrep.yml:25

build process

```
8 paths:
9   - .github/workflows/semgrep.yml
10 scheduler:
11   # random HH:MM to avoid a load spike on GitHub Actions at 00:00
12   - cron: 5 2 * * *
13 name: Semgrep
14 jobs:
15   semgrep:
16     name: semgrep/ci
17     runs-on: ubuntu-latest
18     permissions:
19       contents: read
20     env:
21       SEMGREP_APP_TOKEN: ${ secrets.SEMGREP_APP_TOKEN }
22     container:
23       image: semgrep/semgrep
24     steps:
25       - uses: actions/checkout@v4
26       - run: semgrep ci
```

RULE DETAILS

Medium severity

High confidence

CWE-1357, CWE-353

github-actions-mutable-action-tag

FINDING DETAILS

15 minutes ago

ikeertennah/quickdeliver-scan

main

637f721

by semgrep.dev on behalf of @ikeertennah

<support@semgrep.com>

Screenshot:
terminal
showing
scan
completion

```
Downloading mdurl-0.1.2-py3-none-any.whl.metadata (1.6 kB)
Downloading semgrep-1.168.0-cp310.cp311.cp312.cp313.cp314.py310.py311.py312.py313.py314-none-manylinux_2_34_x86_64.whl (68.8 MB)
68.8/68.8 MB 46.5 MB/s 0:00:01
Downloading mcp-1.23.3-py3-none-any.whl (231 kB)
Downloading ruamel_yaml_clib-0.2.15-cp312-cp312-manylinux2014_x86_64.manylinux_2_17_x86_64.manylinux_2_28_x86_64.whl (788 kB)
788.2/788.2 kB 23.0 MB/s 0:00:00
Downloading boltons-21.0.0-py2.py3-none-any.whl (193 kB)
Downloading click-8.1.8-py3-none-any.whl (98 kB)
Downloading click_option_group-0.5.9-py3-none-any.whl (11 kB)
Downloading exceptiongroup-1.2.2-py3-none-any.whl (16 kB)
Downloading jsonschema-4.25.1-py3-none-any.whl (90 kB)
Downloading opentelemetry_api-1.37.0-py3-none-any.whl (65 kB)
Downloading importlib_metadata-8.7.1-py3-none-any.whl (27 kB)
Downloading opentelemetry_exporter_otlp_proto_http-1.37.0-py3-none-any.whl (19 kB)
Downloading opentelemetry_exporter_otlp_proto_common-1.37.0-py3-none-any.whl (18 kB)
Downloading opentelemetry_proto-1.37.0-py3-none-any.whl (72 kB)
Downloading googleapis_common_protos-1.75.0-py3-none-any.whl (300 kB)
Downloading opentelemetry_instrumentation_requests-0.58b0-py3-none-any.whl (12 kB)
Downloading opentelemetry_instrumentation-0.58b0-py3-none-any.whl (33 kB)
Downloading opentelemetry_semantic_conventions-0.58b0-py3-none-any.whl (207 kB)
Downloading opentelemetry_util_http-0.58b0-py3-none-any.whl (7.7 kB)
Downloading opentelemetry_instrumentation_threading-0.58b0-py3-none-any.whl (9.3 kB)
Downloading opentelemetry_sdk-1.37.0-py3-none-any.whl (131 kB)
Downloading peewee-3.19.0-py3-none-any.whl (411 kB)
Downloading protobuf-6.33.6-cp39-abi3-manylinux2014_x86_64.whl (323 kB)
Downloading pydantic-2.13.4-py3-none-any.whl (472 kB)
Downloading pydantic_core-2.46.4-cp312-cp312-manylinux_2_17_x86_64.manylinux2014_x86_64.whl (2.1 MB)
2.1/2.1 MB 37.7 MB/s 0:00:00
Downloading pyjwt-2.13.0-py3-none-any.whl (31 kB)
Downloading semantic_version-2.10.0-py2.py3-none-any.whl (15 kB)
```

```
@ikeertennah →/workspaces/quickdeliver-scan (main) $ semgrep --config=p/owasp-top-ten quickdeliver.php --output semgrep_results.txt
```

Semgrep CLI

Scanning 1 file (only git-tracked) with 560 Code rules:

CODE RULES

Language	Rules	Files	Origin	Rules
php	22	1	Community	560
<multilang>	5	1		

SUPPLY CHAIN RULES

💡 Sign in with `semgrep login` and run
`semgrep ci` to find dependency vulnerabilities and
advanced cross-file findings.

PROGRESS

100% 0:00:00

Scan Summary

✅ Scan completed successfully.

- Findings: 2 (2 blocking)
- Rules run: 27
- Targets scanned: 1
- Parsed lines: ~100.0%
- No ignore information available

Ran 27 rules on 1 file: 2 findings.

💡 Missed out on 1800 pro rules since you aren't logged in!

⚡ Supercharge Semgrep OSS when you create a free account at <https://sg.run/rules>.

```
@ikeertennah →/workspaces/quickdeliver-scan (main) $ semgrep --config=p/secrets quickdeliver.php --output semgrep_secrets.txt
```

Semgrep CLI

Scanning 1 file (only git-tracked) with 52 Code rules:

CODE RULES

Scanning 1 file with 36 <multilang> rules.

SUPPLY CHAIN RULES

💡 Sign in with `semgrep login` and run
`semgrep ci` to find dependency vulnerabilities and
advanced cross-file findings.

PROGRESS

100% 0:00:00

Scan Summary

✅ Scan completed successfully.

- Findings: 0 (0 blocking)
- Rules run: 36
- Targets scanned: 1
- Parsed lines: ~100.0%
- No ignore information available

Ran 36 rules on 1 file: 0 findings.

💡 Missed out on 218 pro rules since you aren't logged in!

⚡ Supercharge Semgrep OSS when you create a free account at <https://sg.run/rules>.
(need more rules? `semgrep login` for additional free Semgrep Registry rules)

Section 2: OWASP Dependency-Check SCA Results

[8 marks]

Field	Student Entry
OWASP DC version (screenshot)	<pre>@ikeertennah → /workspaces/quickdeliver-scan (main) \$./dependency-check/bin/dependency-check.sh --version Dependency-Check Core version 12.2.2</pre>
Scan command used	<pre>@ikeertennah → /workspaces/quickdeliver-scan (main) \$ wget https://github.com/dependency-check/DependencyCheck/releases/download/v12.2.2/dependency-check-12.2.2-release.zip --2026-07-08 19:50:55-- https://github.com/dependency-check/DependencyCheck/releases/download/v12.2.2/dependency-check-12.2.2-release.zip Resolving github.com (github.com)... 20.205.243.166 Connecting to github.com (github.com) 20.205.243.166 :443... connected. HTTP request sent, awaiting response... 302 Found Location: https://release-assets.githubusercontent.com/github-production-release-asset/5663857/1f3c653d-b11f-4eb2-adc8-e4537861996e?sp=r&sv=2018-11-09&sr=b&sig=b8skv=2018-11-09&sig=%2Fj4FgdZAVRvXwAT2btwtC5ofoQQLd678YXLc%2FHEK3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXRodDIuY29tIiwiaXYktjoiCMVsZWZfZS1hc3NldHMuuz2l0ahVidXNlcmVbnRlbnQuY29tIiwiaWZvb3R1b3RpeSIsImV4cCI6MjAyNjA4MTkxOTQ0LmVudC4uZm9jdGVzdG93cy5uZXQifQ.IzBPBq4UCsNs1Ga_mX0XS9e2S-Bckzg3-RoiVg&response-content-disposition=attachment%3B%20filename%3Ddependency-check-12.2.2-release.zip&response-content-type=application%2Foctet-stream [following] --2026-07-08 19:50:55-- https://release-assets.githubusercontent.com/github-production-release-asset/5663857/1f3c653d-b11f-4eb2-adc8-e4537861996e?sp=r&sv=2018-11-09&sr=b&sig=b8skv=2026-07-08T20%3A27%3A59Z&rscd=attachment%3B+filename%3Ddependency-check-12.2.2-release.zip&rscst=application%2Foctet-stream&skoid=96c2da10-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&ske=2026-07-08T19%3A27%3A46Z&ske=2026-07-08T20%3A27%3A59Z&skv=2018-11-09&sig=4FgdZAVRvX3zeerAwAT2btwtC5ofoQQLd678YXLc%2FHEK3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXRodDIuY29tIiwiaXYktjoiCMVsZWZfZS1hc3NldHMuuz2l0ahVidXNlcmVbnRlbnQuY29tIiwiaWZvb3R1b3RpeSIsImV4cCI6MjAyNjA4MTkxOTQ0LmVudC4uZm9jdGVzdG93cy5uZXQifQ.IzBPBq4UCsNs1Ga_mX0XS9e2S-Bckzg3-RoiVg&response-content-disposition=attachment%3B%20filename%3Ddependency-check-12.2.2-release.zip&response-content-type=application%2Foctet-stream Resolving release-assets.githubusercontent.com (release-assets.githubusercontent.com)... 185.199.108.133, 185.199.110.133, 185.199.109.133, ... Connecting to release-assets.githubusercontent.com (release-assets.githubusercontent.com) 185.199.108.133 :443... connected. HTTP request sent, awaiting response... 200 OK Length: 29439786 (28M) [application/octet-stream] Saving to: 'dependency-check-12.2.2-release.zip' dependency-check-12.2.2-relea 100%[=====>] 28.08M 110MB/s in 0.3s 2026-07-08 19:50:55 (110 MB/s) - 'dependency-check-12.2.2-release.zip' saved [29439786/29439786] @ikeertennah → /workspaces/quickdeliver-scan (main) \$ unzip dependency-check-12.2.2-release.zip Archive: dependency-check-12.2.2-release.zip creating: dependency-check/ creating: dependency-check/bin/ creating: dependency-check/lib/ creating: dependency-check/plugins/ creating: dependency-check/licenses/ creating: dependency-check/licenses/commons-cli/ inflating: dependency-check/bin/completion-for-dependency-check.sh inflating: dependency-check/bin/dependency-check.sh inflating: dependency-check/bin/dependency-check.bat inflating: dependency-check/lib/aho-corasick-double-array-trie-1.2.3.jar inflating: dependency-check/lib/ant-1.10.17.jar inflating: dependency-check/lib/commons-cli-1.11.0.jar inflating: dependency-check/lib/commons-codec-1.22.0.jar inflating: dependency-check/lib/commons-collections4-4.5.0.jar inflating: dependency-check/lib/commons-compress-1.27.1.jar inflating: dependency-check/lib/commons-dbcp2-2.14.0.jar inflating: dependency-check/lib/commons-io-2.22.0.jar inflating: dependency-check/lib/commons-jcs3-core-3.2.1.jar inflating: dependency-check/lib/commons-lang3-3.20.0.jar inflating: dependency-check/lib/commons-pool2-2.13.0.jar inflating: dependency-check/lib/commons-text-1.15.0.jar inflating: dependency-check/lib/commons-validator-1.10.1.jar inflating: dependency-check/lib/compiler-0.9.6.jar inflating: dependency-check/lib/cpe-parser-3.0.1.jar inflating: dependency-check/lib/dependency-check-cli-12.2.2.jar inflating: dependency-check/lib/dependency-check-core-12.2.2.jar inflating: dependency-check/lib/dependency-check-utils-12.2.2.jar</pre>


```

@ikeertennah →/workspaces/quickdeliver-scan (main) $ sudo apt-get update && sudo apt-get install php php-mbstring -y
Get:1 https://packages.microsoft.com/repos/microsoft-ubuntu-noble-prod noble InRelease [3600 B]
Get:2 https://packages.microsoft.com/repos/microsoft-ubuntu-noble-prod noble/main amd64 Packages [207 kB]
Get:3 https://packages.microsoft.com/repos/microsoft-ubuntu-noble-prod noble/main all Packages [643 B]
Get:4 http://archive.ubuntu.com/ubuntu noble InRelease [256 kB]
Get:5 http://security.ubuntu.com/ubuntu noble-security InRelease [126 kB]
Get:6 http://security.ubuntu.com/ubuntu noble-security/main amd64 Packages [1022 kB]
Get:7 http://archive.ubuntu.com/ubuntu noble-updates InRelease [126 kB]
Get:8 http://archive.ubuntu.com/ubuntu noble-backports InRelease [126 kB]
Get:9 http://security.ubuntu.com/ubuntu noble-security/multiverse amd64 Packages [43.8 kB]
Get:10 http://security.ubuntu.com/ubuntu noble-security/restricted amd64 Packages [1417 kB]
Get:11 http://archive.ubuntu.com/ubuntu noble/multiverse amd64 Packages [331 kB]
Get:12 http://security.ubuntu.com/ubuntu noble-security/universe amd64 Packages [1490 kB]
Get:13 http://archive.ubuntu.com/ubuntu noble/restricted amd64 Packages [117 kB]
Get:14 http://archive.ubuntu.com/ubuntu noble/universe amd64 Packages [19.3 MB]
Get:15 http://archive.ubuntu.com/ubuntu noble/main amd64 Packages [1808 kB]
Get:16 http://archive.ubuntu.com/ubuntu noble-updates/restricted amd64 Packages [1490 kB]
Get:17 http://archive.ubuntu.com/ubuntu noble-updates/universe amd64 Packages [2112 kB]
Get:18 http://archive.ubuntu.com/ubuntu noble-updates/main amd64 Packages [1343 kB]
Get:19 http://archive.ubuntu.com/ubuntu noble-updates/multiverse amd64 Packages [49.5 kB]
Get:20 http://archive.ubuntu.com/ubuntu noble-backports/multiverse amd64 Packages [671 B]
Get:21 http://archive.ubuntu.com/ubuntu noble-backports/universe amd64 Packages [35.9 kB]
Get:22 http://archive.ubuntu.com/ubuntu noble-backports/main amd64 Packages [48.9 kB]
Fetched 31.5 MB in 8s (4146 kB/s)
Reading package lists... Done
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  apache2 apache2-bin apache2-data apache2-utils libapache2-mod-php8.3 libapr1t64 libaprutil1-dbd-sqlite3 libaprutil1-ldap libaprutil1t64 liblua5.4
  php-common php8.3 php8.3-cli php8.3-common php8.3-mbstring php8.3-opcache php8.3-readline ssl-cert
Suggested packages:

```

```

@ikeertennah →/workspaces/quickdeliver-scan (main) $ cat composer.json
{
    "name": "quickdeliver/app",
    "description": "QuickDeliver Food Delivery Order Management System",
    "type": "project",
    "require": {
        "php": "^7.4",
        "phpmailer/phpmailer": "5.2.16",
        "guzzlehttp/guzzle": "6.5.5",
        "league/flysystem": "1.1.3",
        "monolog/monolog": "2.3.0"
    },
    "require-dev": {
        "phpunit/phpunit": "9.5.0"
    },
    "autoload": {
        "psr-4": { "QuickDeliver\\": "src/" }
    },
    "config": {
        "optimize-autoloader": true,
        "sort-packages": true
    }
}

```

```

• @ikeertennah →/workspaces/quickdeliver-scan (main) $ composer config policy.advisories.block false
• @ikeertennah →/workspaces/quickdeliver-scan (main) $ composer install --ignore-platform-req=php
No composer.lock file present. Updating dependencies to latest instead of installing from lock file. See ht
Loading composer repositories with package information
Updating dependencies
Lock file operations: 48 installs, 0 updates, 0 removals
- Locking doctrine/deprecations (1.1.6)
- Locking doctrine/instantiator (1.5.0)
- Locking guzzlehttp/guzzle (6.5.5)
- Locking guzzlehttp/promises (1.5.3)
- Locking guzzlehttp/psr7 (1.9.1)
- Locking league/flysystem (1.1.3)
- Locking league/mime-type-detection (1.16.0)
- Locking monolog/monolog (2.3.0)
- Locking myclabs/deep-copy (1.13.4)
- Locking nikic/php-parser (v5.8.0)
- Locking phar-io/manifest (2.0.4)
- Locking phar-io/version (3.2.1)
- Locking phpdocumentor/reflection-common (2.2.0)
- Locking phpdocumentor/reflection-docblock (6.0.3)
- Locking phpdocumentor/type-resolver (2.0.0)
- Locking phpmailer/phpmailer (v5.2.16)
- Locking phpspec/prophecy (v1.26.1)
- Locking phpstan/phpdoc-parser (2.3.3)
- Locking phpunit/php-code-coverage (9.2.32)
- Locking phpunit/php-file-iterator (3.0.6)
- Locking phpunit/php-invoker (3.1.1)
- Locking phpunit/php-text-template (2.0.4)
- Locking phpunit/php-timer (5.0.3)
- Locking phpunit/phpunit (9.5.0)

```

NIST

≡ NVD MENU

Information Technology Laboratory

NATIONAL VULNERABILITY DATABASE

NIST NATIONAL VULNERABILITY DATABASE NVD

Generating Your API Key

Do not leave this page until API key generation and validation are completed.

100%

Validation complete. (0s elapsed)

Your API Key: 563707be-6f8b-4b36-8c57-835bf60c141d

```

• @ikeertennah →/workspaces/quickdeliver-scan (main) $ mkdir dependency-check-report
• @ikeertennah →/workspaces/quickdeliver-scan (main) $ ./dependency-check/bin/dependency-check.sh --project "quickDeliver" --scan vendor/phpmailer --scan vendor/
guzzlehttp --scan vendor/league --format HTML --format JSON --out dependency-check-report/ --nvdApiKey 563707be-6f8b-4b36-8c57-835bf60c141d
[INFO] checking for updates
[INFO] skipping the NVD API update as it was completed within the last 240 minutes
[INFO] skipping Known Exploited Vulnerabilities update check since last check was within 24 hours.
[INFO] check for updates complete (435 ms)
[INFO]

Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis
is performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there are NO warranties, implied
or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright hold
er or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report
.

About ODC: https://dependency-check.github.io/DependencyCheck/general/internals.html
False Positives: https://dependency-check.github.io/DependencyCheck/general/suppression.html

[INFO] Analysis Started
[INFO] Finished File Name Analyzer (0 seconds)
[INFO] Finished Dependency Merging Analyzer (0 seconds)
[INFO] Finished Hint Analyzer (0 seconds)
[INFO] Created CPE Index (5 seconds)
[INFO] Finished CPE Analyzer (5 seconds)
[INFO] Finished False Positive Analyzer (0 seconds)
[INFO] Finished NVD CVE Analyzer (0 seconds)
[INFO] Finished RetireJS Analyzer (0 seconds)
[WARN] Sonatype OSS Index Analyzer disabled due to missing credentials. Authentication with token is now required, and OSS Index is migrating to Sonatype Guide.
See https://dependency-check.github.io/DependencyCheck/analyzers/oss-index-analyzer.html for more information on authentication with Sonatype Guide OSS Index.
[INFO] Finished Vulnerability Suppression Analyzer (0 seconds)

```

	<pre>@likeertennah →/workspaces/quickdeliver-scan (main) \$./dependency-check/bin/dependency-check.sh --project "QuickDeliver" --scan composer.json --format HTML --format JSON --out dependency-check-report/ --nvdApiKey 563707be-6f8b-4b36-8c57-835bf60c141d [INFO] Completed processing batch 1/1 (100%) in 11,406ms [INFO] Skipping Known Exploited Vulnerabilities update check since last check was within 24 hours. [INFO] Begin database defrag [INFO] End database defrag (18771 ms) [INFO] Check for updates complete (131652 ms) [INFO]</pre> Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report. About ODC: https://dependency-check.github.io/DependencyCheck/general/internals.html False Positives: https://dependency-check.github.io/DependencyCheck/general/suppression.html <pre>[INFO] Analysis Started [INFO] Finished File Name Analyzer (0 seconds) [INFO] Finished Dependency Merging Analyzer (0 seconds) [INFO] Finished Hint Analyzer (0 seconds) [INFO] Created CPE Index (3 seconds) [INFO] Finished CPE Analyzer (3 seconds) [INFO] Finished False Positive Analyzer (0 seconds) [INFO] Finished NVD CVE Analyzer (0 seconds) [WARN] Sonatype OSS Index Analyzer disabled due to missing credentials. Authentication with token is now required, and OSS Index is migrating to Sonatype Guide. See https://dependency-check.github.io/DependencyCheck/analyzers/oss-index-analyzer.html for mo re information on authentication with Sonatype Guide OSS Index. [INFO] Finished Vulnerability Suppression Analyzer (0 seconds) [INFO] Finished Known Exploited Vulnerability Analyzer (0 seconds) [INFO] Finished Dependency Bundling Analyzer (0 seconds) [INFO] Finished Unused Suppression Rule Analyzer (0 seconds) [INFO] Analysis Complete (4 seconds) [INFO] Writing HTML report to: /workspaces/quickdeliver-scan/dependency-check-report/dependency-check-report.html [INFO] Writing JSON report to: /workspaces/quickdeliver-scan/dependency-check-report/dependency-check-report.json</pre>
Total vulnerable dependencies	 Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report. How to read the report Suppressing false positives Getting Help: github issues Project: QuickDeliver Scan Information (show less): • <i>dependency-check version:</i> 12.2.2 • <i>Report Generated On:</i> Thu, 9 Jul 2026 01:14:26 GMT • <i>Dependencies Scanned:</i> 283 (202 unique) • <i>Vulnerable Dependencies:</i> 38 • <i>Vulnerabilities Found:</i> 305 • <i>Vulnerabilities Suppressed:</i> 0 • <i>NVD API Last Checked:</i> 2026-07-08T23:37:51Z • <i>NVD API Last Modified:</i> 2026-07-08T23:16:54Z
CVE findings table (CVE ID, Library, Version, CVSS, Severity, Description)	phpmailer:5.2.16 File Path: /workspaces/quickdeliver-scan/composer.lock:phpmailer/phpmailer/5.2.16 Evidence Identifiers • pkg:composer/phpmailer/phpmailer@5.2.16 (Confidence: Highest) • cpe:2.3 a.phpmailer.phpmailer 5.2.16 ***** (Confidence: Highest) suppress • cpe:2.3 a.phpmailer.phpmailer 5.2.16 ***** (Confidence: Highest) suppress Published Vulnerabilities CVE-2016-10033 suppress CISA Known Exploited Vulnerability: • Product: PHPMailer • Name: PHPMailer Command Injection Vulnerability • Date Added: 2025-07-07 • Description: PHPMailer contains a command injection vulnerability because it fails to sanitize user-supplied input. Specifically, this issue affects the 'mail()' function of 'class.phpmailer.php' script. An attacker can exploit this issue to execute arbitrary code within the context of the application. Failed exploit attempts will result in a denial-of-service condition. • Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. • Due Date: 2025-07-29 • Notes: This vulnerability could affect an open-source component, third-party library, protocol, or proprietary implementation that could be used by different products. For more information, please see: https://github.com/PHPMailer/PHPMailer/releases/tag/v5.2.18; https://github.com/advisories/GSA-9527-pwn-2016; https://nvd.nist.gov/vuln/detail/CVE-2016-10033. The mailSend function in the isMail transport in PHPMailer before 5.2.18 might allow remote attackers to pass extra parameters to the mail command and consequently execute arbitrary code via a crafted Sender property. CWE-88 Improper Neutralization of Argument Delimiters in a Command (Argument Injection) CVSSv3: • Base Score: CRITICAL (9.8) • Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/UC:HI/H:A/HP:RC/R:MAVA CVSSv2: • Base Score: HIGH (7.5) • Vector: AV:N/AC:L/Au:N/C:P/I:P/A:P References: • 134c704f-9b21-402e-91b3-4a46735bccc0 - US GOVERNMENT RESOURCE • j82c4a3a-2127-492b-81ae-364592681108 - BROADCAST LINK EXPLAINS THIRD PARTY ADVISORY VDB ENTRY

Screenshot:
HTML
report in
browser
showing
findings
summary

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
code-unit-reverse-lookup@2.0.3	cpe:2.3:a:lookup:lookup@2.0.3:*****	pkg-composer/sebastian/code-unit-reverse-lookup@2.0.3	MEDIUM	1	High	5
config@2.8.1	cpe:2.3:a:sensiolabs:symfony@2.8.1:*****	pkg-composer/symfony/config@2.8.1	CRITICAL	30	Highest	6
console@2.8.1	cpe:2.3:a:sensiolabs:symfony@2.8.1:*****	pkg-composer/symfony/console@2.8.1	CRITICAL	30	Highest	6
diff@1.4.1	cpe:2.3:a:diff:project:diff@1.4.1:*****	pkg-composer/sebastian/diff@1.4.1	CRITICAL	1	High	5
event-dispatcher@2.8.1	cpe:2.3:a:sensiolabs:symfony@2.8.1:*****	pkg-composer/symfony/event-dispatcher@2.8.1	CRITICAL	30	Highest	6
filesystem@3.0.1	cpe:2.3:a:sensiolabs:symfony@3.0.1:*****	pkg-composer/symfony/filesystem@3.0.1	CRITICAL	14	Highest	6
finder@2.8.1	cpe:2.3:a:finder:project:finder@2.8.1:*****	pkg-composer/symfony/finder@2.8.1	MEDIUM	1	High	6
httplib@5.5.4.2.jar	cpe:2.3:a:apache:httplibcomponents_core@5.4.2:*****	pkg-maven/org.apache.httpcomponents.core5/httplibcore5@5.4.2	HIGH	2	Highest	29
httplib@5-h2.5.4.jar	cpe:2.3:a:apache:httplibcomponents_core@5.4:*****	pkg-maven/org.apache.httpcomponents.core5/httplibcore5-h2@5.4	HIGH	2	Highest	29
jackson-databind@2.21.3.jar	cpe:2.3:a:fastxml:jackson-core@2.21.3:***** cpe:2.3:a:fastxml:jackson-databind@2.21.3:***** cpe:2.3:a:fastxml:jackson-modules-java@2.21.3:*****	pkg-maven/com.fastxml.jackson.core/jackson-databind@2.21.3	HIGH	7	Highest	40
json-schema@1.6.0	cpe:2.3:a:json-schema:project:json-schema@1.6.0:***** cpe:2.3:a:schema:project:schema@1.6.0:*****	pkg-composer/justinrainbow/json-schema@1.6.0	MEDIUM	1	High	5
parsedown@1.6.0	cpe:2.3:a:parsedown:parsedown@1.6.0:*****	pkg-composer/erusev/parsedown@1.6.0	HIGH	2	High	5
php-code-coverage@2.2.4	cpe:2.3:a:phpunit:project:phpunit@2.2.4:*****	pkg-composer/phpunit/php-code-coverage@2.2.4	CRITICAL*	3	Low	5
php-code-coverage@9.2.32	cpe:2.3:a:phpunit:project:phpunit@9.2.32:*****	pkg-composer/phpunit/php-code-coverage@9.2.32	HIGH	1	Low	5
php-file-iterator@1.4.1	cpe:2.3:a:file:file@1.4.1:***** cpe:2.3:a:file:project:file@1.4.1:*****	pkg-composer/phpunit/php-file-iterator@1.4.1	HIGH	9	High	5
php-file-iterator@3.0.6	cpe:2.3:a:file:file@3.0.6:***** cpe:2.3:a:file:project:file@3.0.6:*****	pkg-composer/phpunit/php-file-iterator@3.0.6	HIGH	9	High	5
php-timer@1.0.7	cpe:2.3:a:phpunit:project:phpunit@1.0.7:*****	pkg-composer/phpunit/php-timer@1.0.7	CRITICAL*	3	Low	5
php-timer@5.0.3	cpe:2.3:a:phpunit:project:phpunit@5.0.3:*****	pkg-composer/phpunit/php-timer@5.0.3	CRITICAL*	2	Low	5
php-token-stream@1.4.8	cpe:2.3:a:phpunit:project:phpunit@1.4.8:*****	pkg-composer/phpunit/php-token-stream@1.4.8	CRITICAL*	3	Low	5
phpmailer@5.2.16	cpe:2.3:a:phpmailer:phpmailer@5.2.16:***** cpe:2.3:a:phpmailer:project:phpmailer@5.2.16:*****	pkg-composer/phpmailer/phpmailer@5.2.16	CRITICAL*	7	Highest	5
phpunit-mock-objects@2.3.8	cpe:2.3:a:phpunit:project:phpunit@2.3.8:*****	pkg-composer/phpunit/phpunit-mock-objects@2.3.8	CRITICAL*	3	Highest	5
php-file-iterator@1.4.1	cpe:2.3:a:file:file@1.4.1:***** cpe:2.3:a:file:project:file@1.4.1:*****	pkg-composer/phpunit/php-file-iterator@1.4.1	HIGH	9	High	5
php-file-iterator@3.0.6	cpe:2.3:a:file:file@3.0.6:***** cpe:2.3:a:file:project:file@3.0.6:*****	pkg-composer/phpunit/php-file-iterator@3.0.6	HIGH	9	High	5
php-timer@1.0.7	cpe:2.3:a:phpunit:project:phpunit@1.0.7:*****	pkg-composer/phpunit/php-timer@1.0.7	CRITICAL*	3	Low	5
php-timer@5.0.3	cpe:2.3:a:phpunit:project:phpunit@5.0.3:*****	pkg-composer/phpunit/php-timer@5.0.3	CRITICAL*	2	Low	5
php-token-stream@1.4.8	cpe:2.3:a:phpunit:project:phpunit@1.4.8:*****	pkg-composer/phpunit/php-token-stream@1.4.8	CRITICAL*	3	Low	5
phpmailer@5.2.16	cpe:2.3:a:phpmailer:phpmailer@5.2.16:***** cpe:2.3:a:phpmailer:project:phpmailer@5.2.16:*****	pkg-composer/phpmailer/phpmailer@5.2.16	CRITICAL*	7	Highest	5
phpunit-mock-objects@2.3.8	cpe:2.3:a:phpunit:project:phpunit@2.3.8:*****	pkg-composer/phpunit/phpunit-mock-objects@2.3.8	CRITICAL*	3	Highest	5
phpunit@4.7.7	cpe:2.3:a:phpunit:project:phpunit@4.7.7:*****	pkg-composer/phpunit/phpunit@4.7.7	CRITICAL*	2	Highest	5
phpunit@9.5.0	cpe:2.3:a:phpunit:project:phpunit@9.5.0:*****	pkg-composer/phpunit/phpunit@9.5.0	HIGH	1	Highest	5
process@2.8.1	cpe:2.3:a:sensiolabs:symfony@2.8.1:*****	pkg-composer/symfony/process@2.8.1	CRITICAL	30	Highest	6
stopwatch@2.8.1	cpe:2.3:a:sensiolabs:symfony@2.8.1:*****	pkg-composer/symfony/stopwatch@2.8.1	CRITICAL	30	Highest	6
translation@3.0.1	cpe:2.3:a:sensiolabs:symfony@3.0.1:*****	pkg-composer/symfony/translation@3.0.1	CRITICAL	14	Highest	6
validator@2.8.1	cpe:2.3:a:sensiolabs:symfony@2.8.1:*****	pkg-composer/symfony/validator@2.8.1	CRITICAL	30	Highest	6
zend-cache@2.5.3	cpe:2.3:a:zend:zend-cache@2.5.3:***** cpe:2.3:a:zend:zend-framework@2.5.3:*****	pkg-composer/zendframework/zend-cache@2.5.3	CRITICAL	1	Highest	6
zend-config@2.5.1	cpe:2.3:a:zend:zend-framework@2.5.1:*****	pkg-composer/zendframework/zend-config@2.5.1	CRITICAL	3	Highest	6
zend-eventmanager@2.6.1	cpe:2.3:a:zend:zend-framework@2.6.1:*****	pkg-composer/zendframework/zend-eventmanager@2.6.1	CRITICAL	1	Highest	6
zend-filter@2.5.1	cpe:2.3:a:zend:zend-framework@2.5.1:*****	pkg-composer/zendframework/zend-filter@2.5.1	CRITICAL	3	Highest	6
zend-hydrator@1.0.0	cpe:2.3:a:zend:zend-framework@1.0.0:*****	pkg-composer/zendframework/zend-hydrator@1.0.0	CRITICAL	19	Highest	6
zend-119n@2.5.1	cpe:2.3:a:zend:zend-framework@2.5.1:*****					

Screenshot:
individual
CVE detail
panel
showing
NVD link

Screenshot from OWASP DC Html finding link for phpmailer

Information Technology Laboratory

NATIONAL VULNERABILITY DATABASE

NIST

NATIONAL VULNERABILITY DATABASE

VULNERABILITIES

CVE-2016-10033 Detail

Description

The mailSend function in the isMail transport in PHPMailer before 5.2.18 might allow remote attackers to pass extra parameters to the mail command and consequently execute arbitrary code via a \" (backslash double quote) in a crafted Sender property.

QUICK INFO

CVE Dictionary Entry:

CVE-2016-10033

NVD Published Date:

12/30/2016

NVD Last Modified:

06/16/2026

Source:

MITRE

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

NIST: NVD

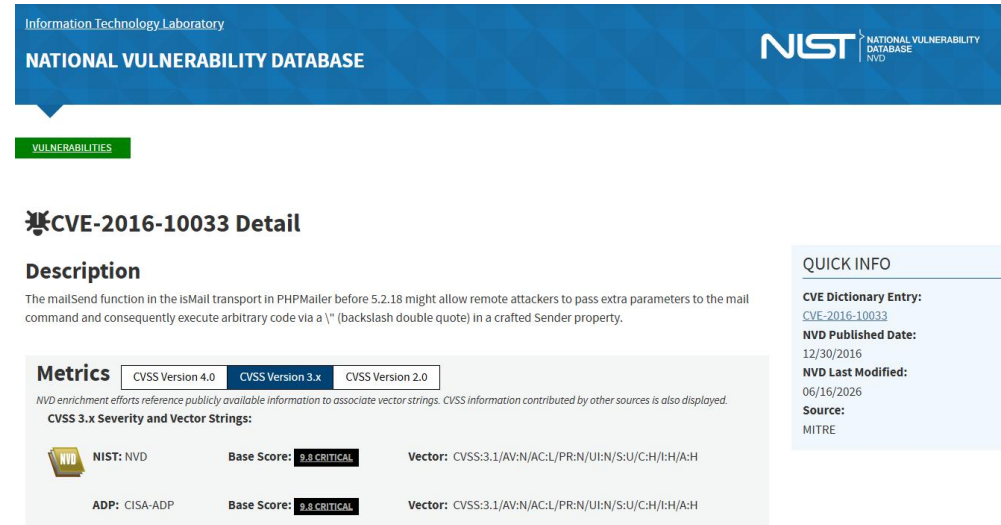
Base Score: 9.8 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

ADP: CISA-ADP

Base Score: 9.8 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H



Screenshot manually from NVD website for guzzle

🚨 CVE-2022-31090 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

Guzzle, an extensible PHP HTTP client. `Authorization` headers on requests are sensitive information. In affected versions when using our Curl handler, it is possible to use the `CURLOPT\_HTTPAUTH` option to specify an `Authorization` header. On making a request which responds with a redirect to a URI with a different origin (change in host, scheme or port), if we choose to follow it, we should remove the `CURLOPT\_HTTPAUTH` option before continuing, stopping curl from appending the `Authorization` header to the new request. Affected Guzzle 7 users should upgrade to Guzzle 7.4.5 as soon as possible. Affected users using any earlier series of Guzzle should upgrade to Guzzle 6.5.8 or 7.4.5. Note that a partial fix was implemented in Guzzle 7.4.2, where a change in host would trigger removal of the curl-added Authorization header, however this earlier fix did not cover change in scheme or change in port. If you do not require or expect redirects to be followed, one should simply disable redirects all together. Alternatively, one can specify to use the Guzzle steam handler backend, rather than curl.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



CNA: GitHub, Inc.

Base Score: 7.7 HIGH

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N

Screenshot manually from NVD website for league/flysystem

🚨 CVE-2021-32708 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

Flysystem is an open source file storage library for PHP. The whitespace normalisation using in 1.x and 2.x removes any unicode whitespace. Under certain specific conditions this could potentially allow a malicious user to execute code remotely. The conditions are: A user is allowed to supply the path or filename of an uploaded file, the supplied path or filename is not checked against unicode chars, the supplied pathname checked against an extension deny-list, not an allow-list, the supplied path or filename contains a unicode whitespace char in the extension, the uploaded file is stored in a directory that allows PHP code to be executed. Given these conditions are met a user can upload and execute arbitrary code on the system under attack. The unicode whitespace removal has been replaced with a rejection (exception). For 1.x users, upgrade to 1.1.4. For 2.x users, upgrade to 2.1.1.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: 8.1 HIGH

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H



CNA: GitHub, Inc.

Base Score: 9.8 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

- c) Cross-analyse the findings from both tools related to the identified vulnerabilities. Identify what each tool detected in Semgrep and OWASP DC, what each tool missed, and evaluate why the two tools are necessary complements rather than alternatives.

Cross- Analysis of Semgrep (SAST) and OWASP DC (SCA)

QuickDeliver's dual-tool review shows that Static Application Security Testing (SAST) and Software Composition Analysis (SCA) should not be regarded as substitute solutions, but rather as constant partners. While this examination was being conducted, Semgrep was employed for the analysis of the custom PHP source code (quickdeliver.php) and OWASP

Dependency-Check was applied for the analysis of the dependency manifest (composer.json and composer.lock). It is apparent from the findings that both tools deal with different types of attack scenarios. Semgrep uncovers defects in proprietary business logic and at the same time OWASP DC deals with software supply chain checks. Furthermore, the review brought to light some weaknesses of the method, since OWASP DC hasn't detected guzzlehttps/guzzle and League/Flysystem as declared in JSON importing format.

1. What Semgrep (SAST) Detected

According to the Semgrep results, the following vulnerabilities related to custom code have been found.

Vulnerability Detected	Location	Description
SQL Injection	quickdeliver.php:25-27	Unsafe \$_GET['keyword'] inserted directly into SQL (SELECT id, name, cuisine, rating FROM restaurants WHERE name LIKE '%' . \$keyword . '%')
Reflected XSS	quickdeliver.php:31	User's input (\$_GET['keyword']) echoed into HTML without employing of htmlspecialchars() function.
CI/CD Misconfiguration	.github/workflows/semgrep.yml:25	Mutable tag reference (actions/checkout@8) used in GitHub Actions workflow, which means supply-chain attacks are possible.

The results in semgrep_results.txt and semgrep_secrets.txt confirm the presence of hardcoded keys (database password, Payment API key, SMTP password) and lack of authentication in the adminGetOrders() function.

2. What OWASP Dependency-Check (SCA) Detected

Here is the information detailed in the OWASP DC HTML report and complemented by some NVD screenshots.

Metric	Result
Total Dependencies Scanned	283 (202 unique)
Vulnerable Dependencies	38
Total Vulnerabilities Found	305
PHPMailer 5.2.16	CVE-2016-10033 (CRITICAL -9.8) Remote Code Execution via mail command injection.

According to the HTML report, PHPMailer 5.2.16 is associated with CVE-2016-10033.

The NVD screenshot provides more information on CVSS vector, namely, the vector is as follows AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H and the Base Score is 9.8.

3. What Each Tool Missed

Tool	Missed Vulnerabilities	Root Cause
Semgrep (SAST)	All 305 third-party library CVEs, including PHPMailer RCE, Guzzle header leak, and Flysystem RCE.	SAST tools did not assess and did not match the versions against NVD.
OWASP DC (SCA)	OWASP DC scanned composer.json and composer.lock, but it still could not map Guzzle 6.5.5 (CVE-2022-31090) and Flysystem 1.1.3 (CVE-2021-32708) to the right CVEs in the HTML report.	SCA tools cannot analyze PHP logic, sanitization of input, or authentication mechanisms. The PHP/Composer analyzer is new and works on Common Platform Enumeration (CPE) mappings. Since CPE mappings for Guzzle and Flysystem are incomplete or outdated in OWASP DC database, the tool cannot match the versions declared to known vulnerability.

4. Addressing the missing guzzlehttp/guzzle and league/flysystem Detection

Even if guzzlehttp/guzzle and league/flysystem appear in both composer.json and composer.lock, OWASP DC has not identified the libraries as being vulnerable. Below are the reasons:

Cause	Explanation
Incomplete CPE Mapping	The CPE mapping for Guzzle and Flysystem in OWASP DC's database is poorly done or outdated as it relates to PHP-related packages compared to other languages such as Java or JavaScript.
Experimental PHP Analyzer	The PHP/Composer analyzer is still in its experimental phase and, therefore, it does not efficiently map some PHP package versions to their corresponding CVEs.

To ensure completeness, these CVEs were manually verified using the official National Vulnerability Database (NVD):

CVE	Library	CVSS Score	Severity
CVE-2022-31090	Guzzle 6.5.5	7.7	HIGH
CVE-2021-32708	League Flysystem 1.1.3	8.1	HIGH

5. Why the two tools are necessary complements than alternatives

The primary reason Semgrep and OWASP Dependency-Check are perfect partners rather than alternatives to each other is their unique and different scopes. Semgrep was developed to inspect the proprietary business logic created by the development team. It processes the structural flow of the quickdeliver.php code to detect implementation problems like SQL injection, cross-site scripting, and the presence of hardcoded passwords. OWASP Dependency-Check checks the external software supply chain, analyzing dependency manifests (composer.json and composer.lock) and correlating package version numbers with the vulnerabilities present in the National Vulnerability Database (NVD). This distinction is crucial as a vulnerability of one layer can go unnoticed by the tool analyzing the other. Semgrep cannot scan the vendor/ directory or correlate the CPE entries whereas OWASP DC cannot analyze the custom PHP code or detect the absence of some authentication processes. Thus, if QuickDeliver relied only on SAST, the application would have been patched against the injection attacks but remained vulnerable to the immediate takeover of a server via the PHPMailer remote code

execution (CVE-2016-10033). On the other hand, if the organization were dependent solely on SCA, external libraries would be checked for existing vulnerabilities, but an attacker could easily extract the entire database from production due to errors in the custom software.

This complementarity can be best explained through the attack chain constructed in Question 1(c)(i), which involves both mechanisms for completion. The attacker uses the unauthenticated admin panel during the reconnaissance phase of the attack, and this vulnerability can only be identified by Semgrep, thus helping to obtain valid `order_id` and `total` parameters from the production database. The exploitation phase of the attack uses the PHPMailer RCE vulnerability, which allows the attack to execute a system command without being detected by conventional web application firewalls, thanks to the valid parameters that Semgrep provided. Without Semgrep, the attack could not have received the valid context to avoid being caught; without OWASP DC, the attacker would not have had the necessary weapon to use after reconnaissance. Besides, the two attacks have very different methods of remediation. For example, the process of addressing SQL injection problems requires revising PHP code, whereas fixing PHPMailer problems involves updating `composer.json` and executing the composer update. No developer or team can address both types of vulnerabilities, which demonstrates the necessity of the integration of both tools into the software development lifecycle.

In conclusion, this assessment clearly illustrates the importance of utilizing this dual strategy as shown by the shortcomings encountered while conducting the SCA scan of `composer.json`. Even though the dependency file makes it clear that Guzzle 6.5.5 and Flysystem 1.1.3 are part of the dependencies utilized, OWASP Dependency-Check was not able to assign the two libraries with any CVEs (CVE-2022-31090 and CVE-2021-32708) due to incomplete CPE records as well as the fact that the PHP analyzer is still experimental. This serious issue demonstrates the failure of automated tools and the importance of human intervention in analyzing the findings and analyzing the NVD database manually to fill the gaps between SAST and SCA tools. To sum up, a truly effective and comprehensive security state can be established only when SAST serves to protect the code developed in-house, SCA is used for the protection of libraries provided from third-party suppliers, and manual verification takes place to help overcome the lack of automation.

6. Summary of the Finding

Dimension	Semgrep (SAST)	OWASP Dependency-Check (SCA)
Primary Scope	First-party PHP source code (quickdeliver.php)	Third-party dependencies (composer.json)
Vulnerabilities Detected	SQL Injection, XSS, Hardcoded Secrets, Missing Authentication, Missing CSRF, CI/CD misconfiguration	305 CVEs, including PHPMailer (CVE-2016-10033)
Missed Vulnerabilities	All library CVEs	All custom code flaws and guzzlehttp/guzzle and league/flysystem due to tool limitations
Detection Mechanism	AST pattern matching	File hashing, CPE mapping and NVD correlation
Remediation	Code rewrites	Package updates

[10 Marks]

[END OF QUESTIONS]

APPENDIX A: QuickDeliver PHP Application Source Code

File: quickdeliver.php

Version: 1.4.2

Developer: Amirul Hakim

Last Updated: 2025-02-14

```
<?php
// =====
// QUICKDELIVER SDN. BHD. -- Food Delivery Order Management
// Version: 1.4.2 | Developer: Amirul Hakim
// Dependencies: Refer to composer.json (Appendix B)
// =====
require_once 'vendor/autoload.php';

use PHPMailer\PHPMailer\PHPMailer; // v5.2.16
use GuzzleHttp\Client; // v6.5.5
use League\Flysystem\Filesystem; // v1.1.3
use League\Flysystem\Adapter\Local;

// Database configuration
$db = new mysqli("localhost", "root", "QkDel!v3r2025", "quickdeliver");

// Payment API key hardcoded
$PAYMENT_API_KEY = "pgw_live_sk_Qk9OKZM3NwRtP7vLs2HcYbAe4xJd";

// MODULE 1: Restaurant Search
function searchRestaurants() {
    global $db;
    $keyword = $_GET['keyword'];
    // SQL Injection: unsanitised GET parameter in query
    $sql = "SELECT id, name, cuisine, rating FROM restaurants"
        . " WHERE name LIKE '%" . $keyword . "%'";
    $result = $db->query($sql);
    $data = [];
    while ($row = $result->fetch_assoc()) { $data[] = $row; }
    // Reflected XSS: user input echoed without encoding
    echo "<h3>Results for: " . $_GET['keyword'] . "</h3>";
    return $data;
}

// MODULE 2: Place Order and Charge Payment
function placeOrder($customer_id, $restaurant_id, $total) {
    global $db, $PAYMENT_API_KEY;
    // No CSRF token validated
    $client = new Client();
    $response = $client->post('https://api.paygateway.com.my/charge', [
        'headers' => ['Authorization' => 'Bearer ' . $PAYMENT_API_KEY],
        'json' => ['amount' => $total, 'currency' => 'MYR']
    ]);
    $charge = json_decode($response->getBody(), true);
    if ($charge['status'] === 'success') {
        $stmt = $db->prepare("INSERT INTO orders (customer_id, restaurant_id,"
            . " total, status) VALUES (?, ?, ?, 'confirmed')");
        $stmt->bind_param("iid", $customer_id, $restaurant_id, $total);
        $stmt->execute();
        return $db->insert_id;
    }
    return null;
}
```



```

// MODULE 3: Send Order Confirmation Email
function sendConfirmationEmail($to, $order_id, $total) {
    $mail = new PHPMailer();
    $mail->isSMTP();
    $mail->Host      = 'smtp.quickdeliver.com.my';
    $mail->SMTPAuth = true;
    $mail->Username = 'orders@quickdeliver.com.my';
    $mail->Password = 'SMTPp@ssQD2025!';
    // CVE-2016-10033: sender_name from POST passed to setFrom without sanitisation
    $mail->setFrom('orders@quickdeliver.com.my', $_POST['sender_name']);
    $mail->addAddress($to);
    $mail->Subject = "Order #{$order_id} Confirmed -- QuickDeliver";
    $mail->Body    = "Your order of RM$total has been confirmed.";
    $mail->send();
}

// MODULE 4: Upload Order Receipt
function uploadReceipt($order_id, $file) {
    // CVE-2021-32708: filename from client with no unicode validation
    $adapter = new Local('/var/www/quickdeliver/receipts/');
    $filesystem = new Filesystem($adapter);
    $filename = $order_id . '_' . $file['name'];
    $filesystem->write($filename, file_get_contents($file['tmp_name']));
    return $filename;
}

// MODULE 5: Admin -- View All Orders
function adminGetOrders() {
    global $db;
    // No authentication check -- accessible to anyone
    $result = $db->query(
        "SELECT o.id, c.name, c.phone, c.address, o.total, o.status"
        ." FROM orders o JOIN customers c ON o.customer_id = c.id"
    );
    while ($row = $result->fetch_assoc()) {
        echo "<tr><td>{$row['id']}</td><td>{$row['name']}</td>"
            ."<td>{$row['phone']}</td><td>{$row['address']}</td>"
            ."<td>RM{$row['total']}</td></tr>";
    }
}

// Request Dispatcher
$action = $_GET['action'] ?? $_POST['action'] ?? '';
switch ($action) {
    case 'search': searchRestaurants(); break;
    case 'order':  placeOrder($_POST['cid'], $_POST['rid'], $_POST['total']); break;
    case 'email':  sendConfirmationEmail($_POST['email'],
                                         $_POST['oid'], $_POST['total']); break;
    case 'upload': uploadReceipt($_POST['oid'], $_FILES['receipt']); break;
    case 'admin':  adminGetOrders(); break;
}
?>

```

APPENDIX B: Project Dependency Manifest (*composer.json*)

```
{
  "name": "quickdeliver/app",
  "description": "QuickDeliver Food Delivery Order Management System",
  "type": "project",
  "require": {
    "php": "^7.4",
    "phpmailer/phpmailer": "5.2.16",
    "guzzlehttp/guzzle": "6.5.5",
    "league/flysystem": "1.1.3",
    "monolog/monolog": "2.3.0"
  },
  "require-dev": {
    "phpunit/phpunit": "9.5.0"
  },
  "autoload": {
    "psr-4": { "QuickDeliver\\\\" : "src/" }
  },
  "config": {
    "optimize-autoloader": true,
    "sort-packages": true
  }
}
```